

iPAS 資訊安全工程師

初級能力鑑定



簡志峰

鑑定制度架構

專業及級等	建議報考對象	考試科目	評鑑方法
Level1 初級資訊安全工程師	建議符合下列任一項條件： - 大專或技職校院學生(含畢業生) - 具備資訊安全知識與能力，或對資訊安全有興趣者。 ※以資通訊相關科系大三以上學生應考為佳	1.資訊安全管理概論 2.資訊安全技術概論	電腦測驗 (單選)

通過及授證標準

- 每科100分，單科成績達到70分為合格
- 達70分之單科成績，可保留三年
- 一次報考同一級等的所有考科，平均達70分得視為及格，但單科成績不得低於60分。

初級考試評鑑內容-資訊安全管理概論

※單科考試時間75分鐘、考50題單選題

科目	評鑑主題	評鑑內容	知識點
科目一： 資訊安全管理概論	1.資訊安全管理概念	1-1.資訊安全管理系統	- 資料機密性、完整性與可用性之定義、基本觀念，以及情境應用之理解 - 資訊安全管理系統之基本觀念，如：導入步驟、ISO標準驗證、稽核活動、系統監控、實體控制措施等 - 國內外重要資安法規，合規集隱私相關框架作業規範 - 與時事相關之重要資安事件與概念
		1-2.相關法規概論與遵循	
		1-3.隱私權保護與智慧財產權	
	2.資產與風險管理	2-1.資產分類分級與盤點	- 資訊資產分類分級與盤點之基本觀念 - 資訊資產管理原則與程序之基本觀念 - 風險定義、風險評估與處理及風險評鑑之基本觀念
		2-2.風險評鑑與風險處理	
	3.存取控制、加解密與金鑰管理	3-1.存取控制與身份認證	- 存取控制的方法與原則之基本觀念，如：網路系統存取管理、組織內部存取控制政策等 - 權限管理與身分認證機制之基本觀念，如：生物特徵辨識、金鑰、憑證、加解密機制等
		3-2.加解密與金鑰生命週期	
	4.事故管理與營運持續	4-1.事件與事故管理	- 事故處理之基本觀念，如：通報應變作業、日誌比對、證據保管鏈等 - 資料備援與營運持續管理之基本觀念
		4-2.備援與營運持續	

資訊安全工程師-初級能力鑑定

資訊安全管理概論



資訊安全管理概論考題方向

- ◆資訊安全管理概念
- ◆資產與風險管理
- ◆存取控制、加解密與金鑰管理
- ◆事故管理與營運持續

資訊安全管理概念

機密性、完整性與可用性定義

資訊安全管理系統

認識資訊安全(information security)

- ◆ 資訊安全(information security)是組織與企業的資訊運用與管理中非常重要的一環。

「資訊」是知識存在的一種形式，也是人類智慧的產物，可以當成一種資源或是資產。

「安全」指免於危難，所以資訊安全探討的就是讓資訊免於危難，得以永久保存與運用。

- ◆ 系統的安全管理探討作業系統的管理範圍內，對於資源(resources)以及系統本身的安全維護措施與機制，

防止未經授權的使用、資源的濫用或是竄改。所謂的資源就包括資訊在內。

- ◆ 「安全性的侵犯或攻擊」(Security Attack)，是指外來或是內部引發的行動，造成資料的損害或是變更。

- ◆ 由於程式本身也可以看成是資料的一種，安全性的侵犯也會造成系統無法正常運作。

建立資訊安全的危機意識

- ◆ 資訊安全的實際案例很多，遇到資安事故雖然是很多人的噩夢，但是沒有遭遇時還是容易有僥倖的心態。

既然大多數人都是資訊環境與設施的使用者，一定要有資安的認知與警覺，才不會深受其害。

- ◆ 資安的攻擊無孔不入，影響層面大，可能產生的危害超出一般人的想像。現代的資安維護是每一個人應有的責任與警覺，資安的素養與專業是現代公民需要培養的生活與工作知能。

了解資安威脅

◆ 以下是常見的資安威脅：

- 社群網路上的個資外洩
- 針對關鍵資訊基礎設施的破壞
- 雲端運算與虛擬化環境的資安威脅
- 手機成資安威脅的新平台
- 針對網頁與網站的攻擊
- 社交工程攻擊採取更細膩的手法
- 組織化網路犯罪與詐騙
- 駭客以APT(advanced persistent threat)攻擊竊取機密
- 透過資訊戰與分散式阻斷服務攻擊的手法藉以癱瘓國家網路
- 恐怖組織以資安做為恐怖攻擊的工具

資訊安全的範疇

- ◆ 資訊安全是比較廣義的電腦安全，包含了硬體、軟體、資料與人員等，可能產生的問題五花八門，例如電腦故障、軟體被更改、資料被竊取、或是駭客入侵，都會對資訊安全產生危害，因此我們必須做好資訊安全的管理工作。



認識安全問題

- ◆ 假如一個系統是安全的(**secure**)，表示其資源的使用在任何情況下都在原來的預期中。若不在預期中的情形發生就有可能
是安全上的破壞。
- ◆ 系統的安全違規(**security violation**)可以分成兩大類：蓄意的(**intentional**或**malicious**)與意外的(**accidental**)。
蓄意的破壞又可分成下列3種
 1. 資料的竊取(**unauthorized read**)
 2. 未經允許修改資料(**unauthorized write**)
 3. 未經允許破壞資料(**unauthorized destruction**)

從不同層次來思考保護系統安全的方法

- ◆ 電腦系統的安全問題可以從很多角度來觀察，作業系統的安全只是其中的一部分。舉例來說，淹水的時候電腦泡水就沒有辦法使用了，這種安全問題跟災難的防範有關。
- ◆ 保護系統安全的方法可以從幾個層次來思考：
 - **實體的層次(physical level)**：電腦系統所在的位置是否安全？能否防止侵入者輕易地接觸後破壞？
 - **系統的層次(system level)**：作業系統是否有可利用的漏洞？網路是否有可乘之機？這些問題跟技術的關係比較密切。
 - **人為的層次(human level)**：電腦系統的管理者與使用者是否會協助入侵者，與人員的管理有關。

資訊安全的目標

- ◆ 機密性(confidentiality)、完整性(integrity)與可用性(availability)是資訊安全的目標，也常被稱為資訊安全大三角(CIATriad)。也有人把法規遵循(compliance)列為資安目標之一，這些目標也常稱為資訊安全的基本原則。
- ◆ 任何的資訊安全的努力都是為了維繫安全的基本原則，資安的技術也是在這些基本原則上發展出來的。
 - **機密性(confidentiality)**：機密性是指資訊是否能維持保密，透過適當的機制只讓有合法權限的人使用。
 - **完整性(integrity)**：完整性指資訊的正確性，應能透過適當的機制避免資訊被非法地竄改。
 - **可用性(availability)**：可用性指資訊在需要時能正常地被使用，可以透過環境維持穩定運作持續讓人使用。

安全模型(security model)

- ◆ 當我們對一個安全的系統(secure system)進行分析與設計時，會需要一個安全模型(security model)，描述系統遵行的安全政策(security policy)，同時把安全的要求對應到系統必須遵循的規則。
- ◆ 資訊安全政策是一個安全系統在資訊安全上要達到的目標，抽象的資訊安全政策必須以資訊系統的專用術語來描述，透過資料結構與技巧在實務面上實現。

資訊安全的三個目標

- ◆ 資訊安全的目的，在於防止未經授權的人，對資料進行存取、記錄、散佈、修改與刪除操作。
- ◆ 依據 ISO/IEC27001 標準的描述，資訊安全管理的目的是透過規劃、建立、執行與監督的機制，保護資訊資產，也就是維護資訊資產的機密性、完整性與可用性。
- ◆ 資訊安全的三個核心概念(CIA)：機密性、完整性、可用性。



資訊安全的三個目標

◆ 機密性(Confidentiality)：

資訊之秘密性與隱私性，應防止機密資訊外洩。

◆ 完整性(Integrity)：

資訊或系統之正確性，應防止人為刻意竄改、自然雜訊干擾，以及防制假冒或未授權方式存取系統資源進行處理或更改。

◆ 可用性(Availability)：

資訊與資訊處理的可獲得性，應避免資訊因系統故障或人為惡意的阻斷服務。

完整性

機密性



保護資訊 C.I.A. 不同的技術與方法

◆ 機密性保護(Confidentiality) :

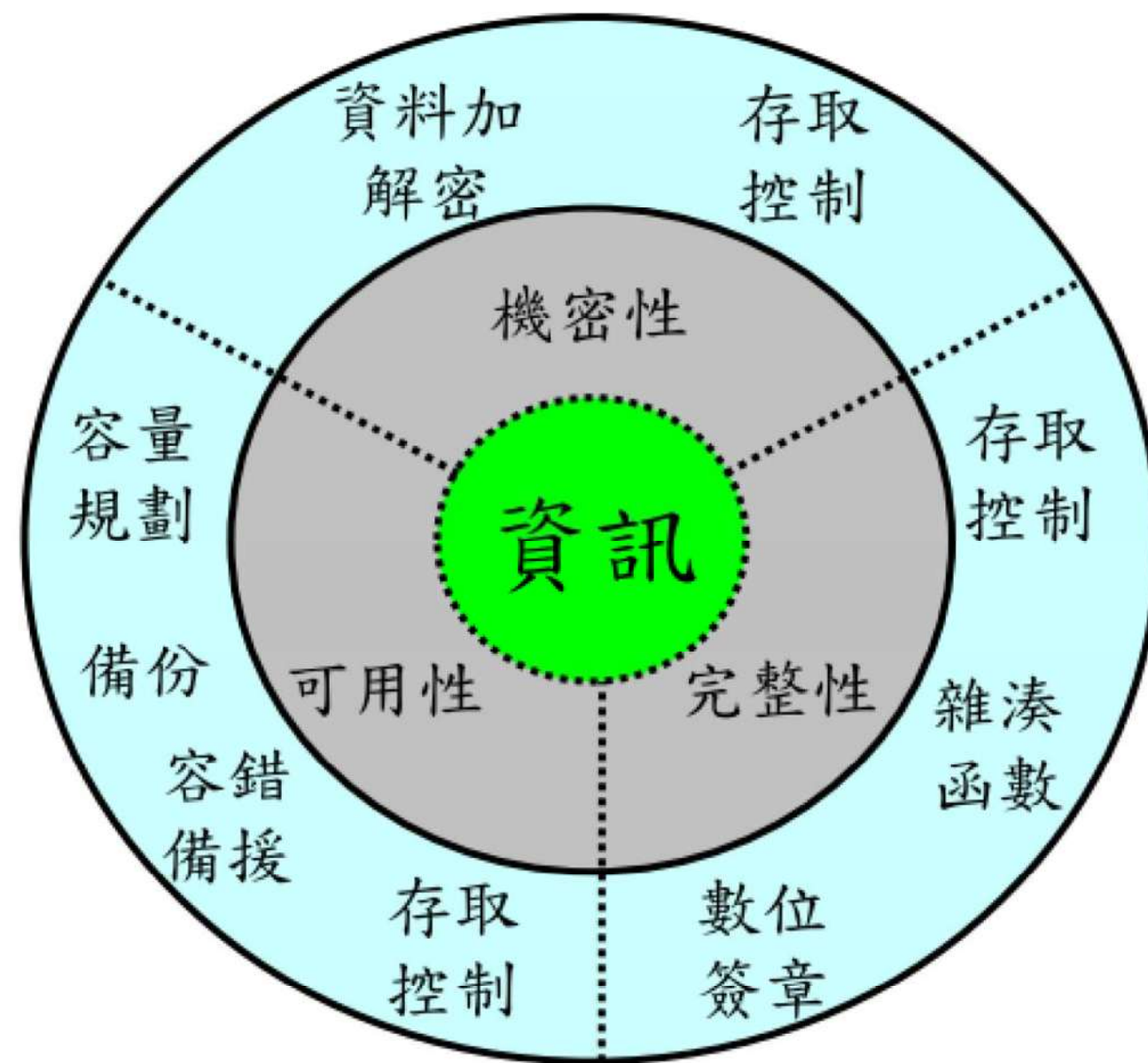
- 存取控制
- 加解密技術

◆ 完整性保護(Integrity) :

- 存取控制
- 雜湊函數
- 數位簽章

◆ 可用性保護(Availability) :

- 備份
- 容量規劃
- 存取控制
- 容錯、備援及負載平衡



不同的安全性需求使用
不同的方法與技術

資訊安全管理制度的導入

- ◆ 資訊安全必須經過檢驗(evaluation)，針對系統與安全相關的部分依據標準來檢視，包括 TCB、存取控制，與保護機制等，因此有所謂的安全確保的評估程序(Assurance evaluation process)，這樣的程序必須搭配資訊安全的標準來進行檢驗，才能夠精確而客觀。

國際資訊安全稽核規範的由來

◆ BS7799 是一種「國際資訊安全稽核規範」，全名為「BS7799 Code of Practice for Information Security」。

英國標準協會(British Standards Institute) 於西元 1995 年提出 BS7799，被ISO(International Organization for Standardization) 採用為國際標準。

◆ BS7799 涵蓋了安全政策的建立、風險的評估，BS7799 分成 PART-1 與 PART-2 兩個部分

- PART-1 提供操作性的指引(Code of Practice)，PART-2是資訊安全管理系統(ISMS)
- PART-1 修訂後成為ISO/IEC17799的國際標準，ISO/IEC17799於2007年重新編號為ISO27002
- PART-2 成為ISO27001的國際標準，也就是一般資訊安全管理制度導入所遵循的標準

◆ PDCA模式：BS7799 資訊安全標準採用所謂的「流程導向的方法」，也就是 PDCA 模式，P代表「計畫(Plan)」，
D 代表「執行(Do)」，C 代表「檢查(Check)」，A 代表「反應(Act)」，以此為基礎來推動組織機構的資訊安全管理系統。

ISO 17799 與 BS7799 part 2

• ISO 17799 (CNS 17799-1)

- 施行細則
- 參考文件
- 完整的最佳資訊安全管理範例

• BS7799 Part 2 (CNS 17799-2)

- 以 ISO 17799 為基礎
- 規範了建立執行和文件劃一套資訊安全管理系統的要求
- 驗證標準

資訊安全管理制度導入的內涵

- ◆ ISMS 是在 BS7799 的 PART-2 中描述的，後來成為 ISO27001 國際標準的基礎，同時也是我國的 CNS27001 國家標準，所以從 CNS27001 的文件基本上就可以看到 ISMS 的主要內涵。



ISMS 資訊安全管理制度

- ◆ ISMS，Information Security Management System，是一套有系統地分析和**管理**資訊安全風險的方法。
- ◆ 資訊安全管理的目標是透過控制方法，把資訊風險降低到可接受的程度內。
- ◆ 我國的政府機關、企業界、組織單位以實施資訊安全管理系統(ISMS)，導入ISO作為其風險管理策略之一環，而新版ISO標準之發行更及時的提供對資訊安全管理系統的整體概念。
- ◆ ISO/IEC27001:2005(資訊安全管理系統)提供了資訊技術、安全技術、資訊安全管理系統三者的整體概念，以協助各種不同類型之企業組織、各部室單位了解如何改善保護他們的資訊資產的基本原則、原理與觀念。

◆ 重要性

- 表達提供安全營運環境的決心與承諾。
- 定義使用資訊與資訊系統的規範。
- 策劃資訊安全架構。
- 為管理階層與全體員工溝通之依據。



ISMS 資訊安全管理制度目標

◆對內

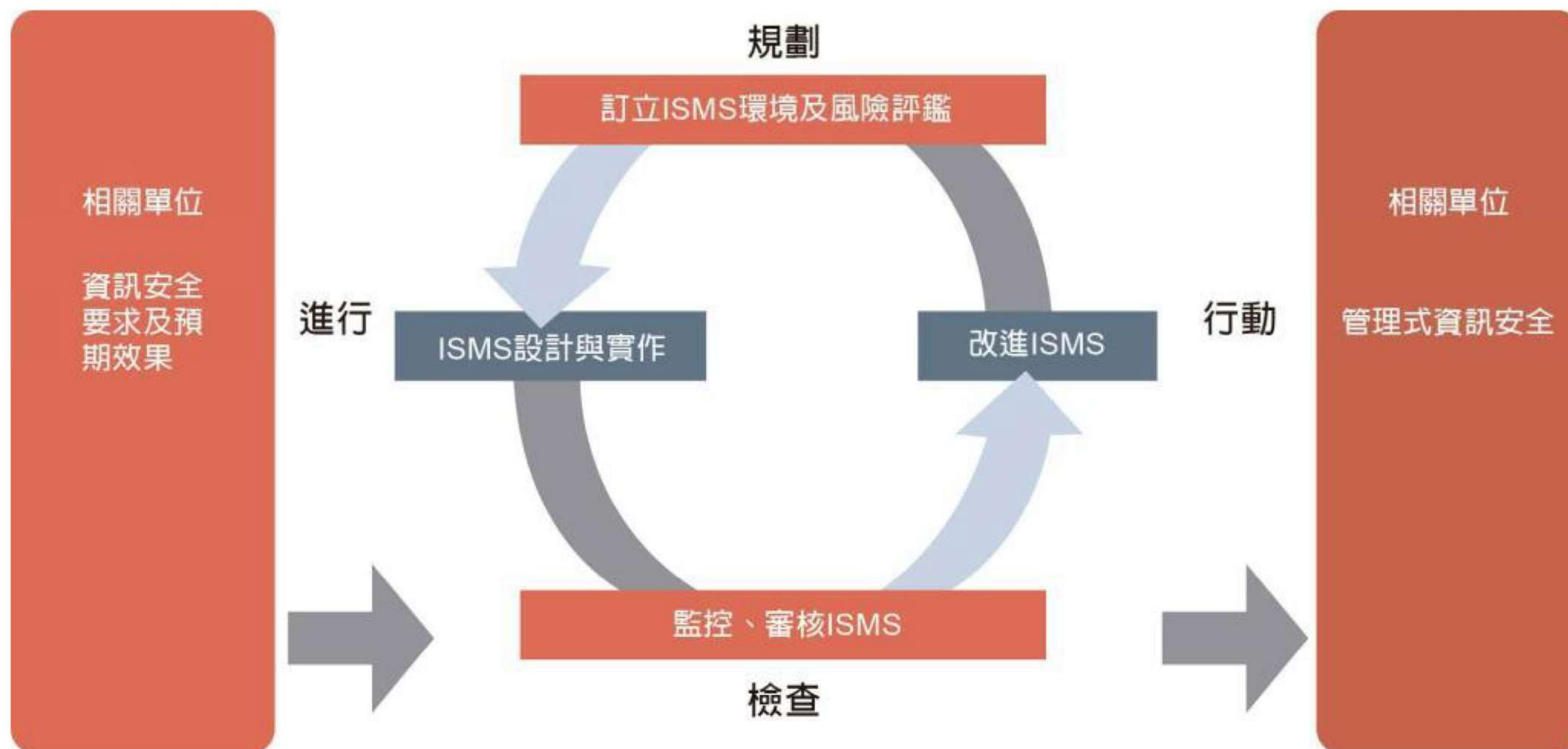
- 企業具備安全管理能力。
- 建立「安全等級」資訊管理制度。
- 為資訊架設一套安全防護機制。

◆對外

- 防範病毒及駭客入侵。
- 遭受攻擊時，系統仍可維持正常運作能力。



ISMS 運作模式



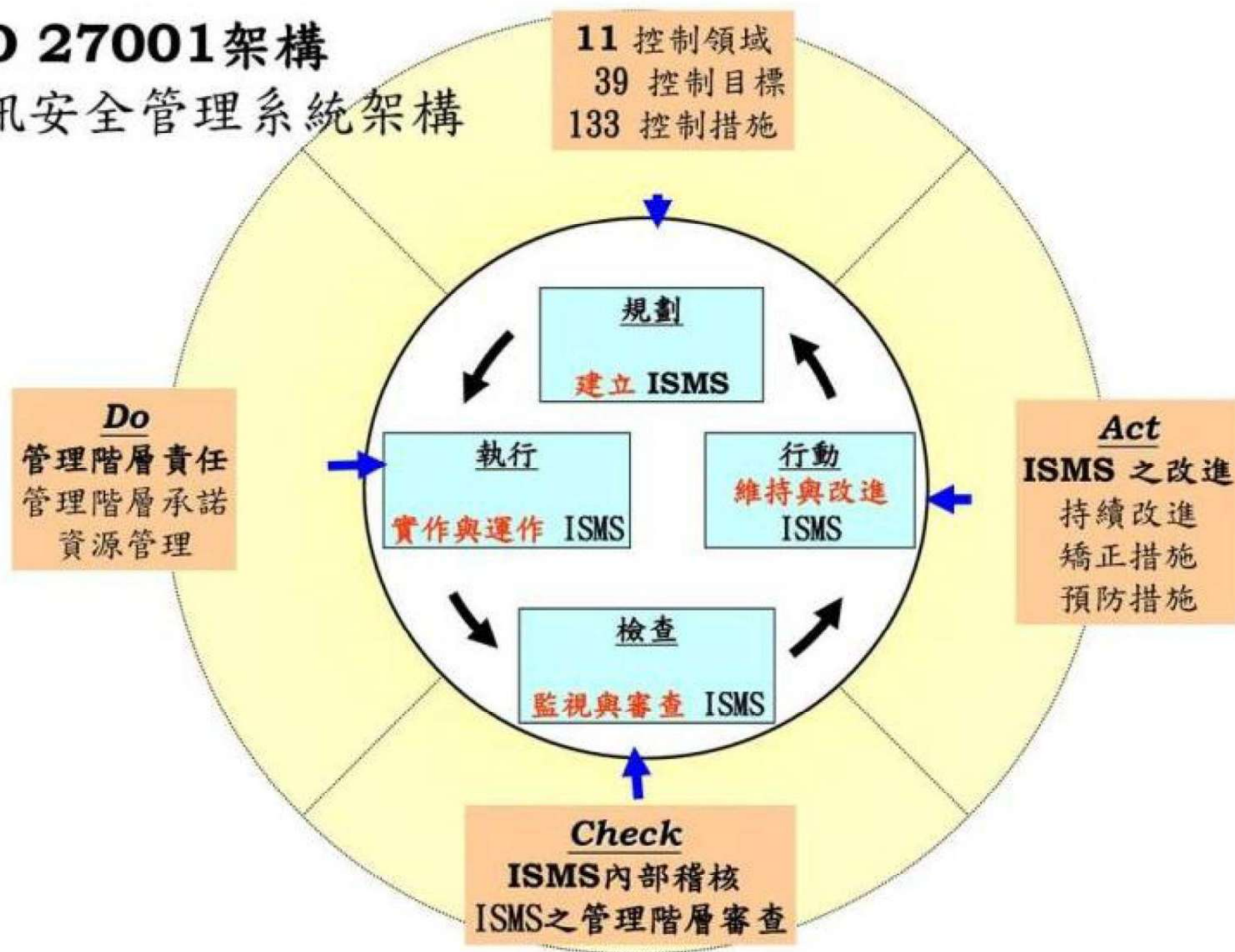
ISO27001架構

ISO 27001 架構



ISO27001架構

ISO 27001架構 資訊安全管理系統架構



為何要執行資安管理系統(ISMS)

法規遵循

1. 依據我國政府相關規定行政院及所屬各機關資訊安全管理要點，行政院有訂定「**行政院及所屬各機關資訊安全管理規範**」，供全國政府機關(構)參考施行。
2. 「**建立我國通資訊基礎建設安全機制計畫**」，緣由起因於資訊通訊科技蓬勃發展，網際網路(Internet)隨之興起，基於開放、自由、易於使用等特性，不僅是個人、組織、政府間訊息交換、傳佈的主要管道，資訊應用及整備度等更成為國際間衡量國家競爭力的重要指標。

ISMS 執行重點參考

◆ 資料分類並採取相對應控管措施

- 針對不同重要性等級的資料進行分類，找出企業營運的重要資料。
- 例如個資、財務資料、客戶資料、營業秘密，進行風險分析(risk analysis)等，並將之採取風險降低(risk mitigation)、風險接受(risk acceptance)、風險規避(risk avoidance)或風險轉移(risk transfer)，施加不同回應方式及控管程度的處理，可有助企業有效保護企業資料，且達到成本效益之優點。

ISO 27000

◆ ISO 27000 開頭的都是資安相關的國際標準，其目的在於制定一個可用來建立、實作、運作、監視、審查、維持及改進「資訊安全管理系統」(Information Security Management System, ISMS)的模型。

◆ 雲端安全相關的 ISO 27017與 ISO 27018

- ISO/IEC 27017 《雲端運算服務的資訊安全控制措施實務守則》
- ISO/IEC 27018 《公有雲個人資料(PID)處理者之個資「保護作業規範」



ISO 27000



ISO 27001

- ◆ ISO27001：2013 內容包含了本文，及附錄的 35 項控制目標(共114項控制措施)，是相當具有依循價值的標準。

若能導入 ISO27001 此一國際標準，將有助從法遵的合規性、技術及管理的有效性來對資訊安全作出整體的思考。



ISO 27001 導入目的

- ◆ 提升企業整體競爭力及形象。
- ◆ 確保業務資訊之機密性、完整性與可用性。
 - 機密性：確保被授權之人員才可使用資訊。
 - 完整性：確保使用之資訊正確無誤、未遭竄改。
 - 可用性：確保被授權之人員能取得所需資訊。
- ◆ 鑑別資訊安全管制點，包括組織員工、客戶、供應商與股東。
- ◆ 消除與日俱增之資訊安全威脅，如：營業機密(研發成果)、欺詐、間諜、破壞、毀損、天災、電腦病毒、駭客入侵等。
- ◆ 建立資訊硬體設施及軟體之管理機制，以統籌分配、運用全公司資源。
- ◆ 實施資訊安全教育訓練，宣導資訊安全政策及相關實施規定。
- ◆ 建立適切之管理程序流程，確保資訊安全。
- ◆ 明確規範資訊系統及網路服務之使用權限，防止未經授權之存取動作。
- ◆ 訂定資訊作業安全災變回復計畫並實際演練，確保業務持續運作。
- ◆ 強化風險管理。

Q&A

法規遵循與資訊倫理

資訊倫理、法規遵循(含GDPR)與稽核

隱私保護與智慧財產權

與資訊科技相關的法律

- ◆ 資訊科技法律以及電腦犯罪的相關主題是近年來相當受矚目的領域。隨著資訊科技使用者的增加，電腦與網路的虛擬世界逐漸成為犯罪的溫床。
- ◆ 對於現代的資訊公民來說，一定要有資訊法律方面的素養，把傳統社會中倫理道德的好規範也搬到資訊社會中努力實踐。
- ◆ 現有的法律是以有形的物體為對象，資訊本身沒有具體的外形，而且法律的適用性有地理的限制，資訊卻沒有這樣的限制，因為透過網路的傳遞可以讓資訊跨越各種界限。
- **資訊的所有權**：資訊可能來自原始創作，資訊的擁有者對於所擁有的資訊具有一些基本的權利。
- **資訊安全**：資訊安全探討資訊的完整性、機密性與真實性，法律對於資訊安全必須訂定適當的規範。
- **資訊內容**：資訊內容的特質可能需要受到法律的規範，在處理與使用上必須遵循法律的規定。

資訊法律所涵蓋的領域

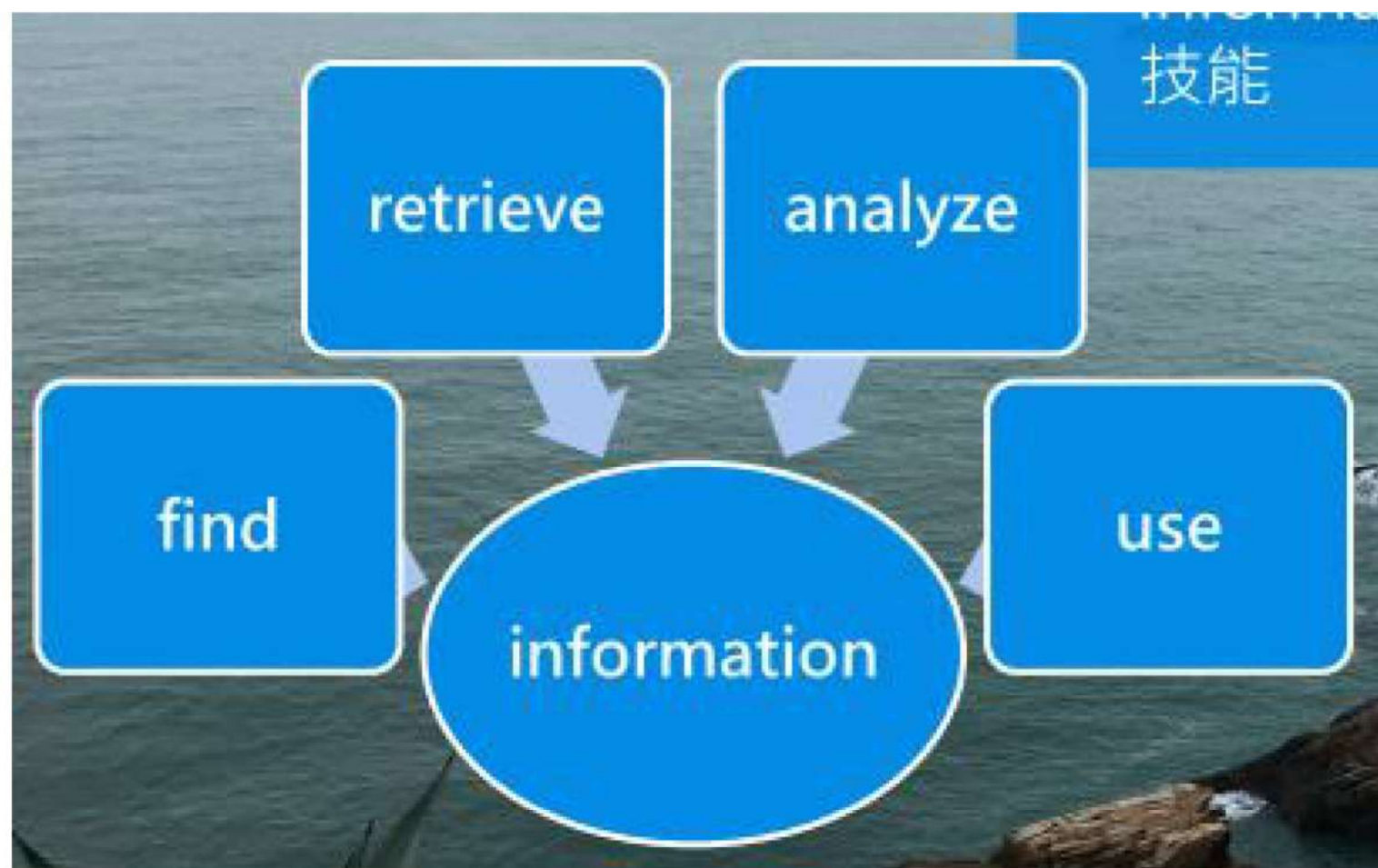
◆ 資訊法律是一個變化快速的領域，以往發生法律訴訟時，一般人還可以到圖書館找尋相關的書籍，了解法律條文與判例。

資訊法律的資訊還沒有那麼充裕，而且新增的資訊很多，法律的訂定還有待努力。以下是資訊法律所涵蓋的領域：

- 資訊隱私權
- 資訊言論權
- 資訊智慧財產權
- 資訊消費者保護權
- 因資訊科技危害人格權

資訊素養 (information literacy)

- ◆ 「資訊素養」的名詞是在西元1974年的時候，由美國的Paul Zurkowski 所提出來的，西元1989年美國圖書館協會（ALA）
- ◆ 把資訊素養定義為：Information Literacy is the set of skills needed to find , retrieve , analyze , and use information ;
也就是一般人尋找、取得、分析與使用資訊的技能。



認識資訊倫理

- ◆ 資訊革命的影響使傳統的社會轉變成所謂的資訊社會，生活在資訊社會裡頭的人們必須在這樣的新環境下，建立適當的制度與核心價值，使資訊科技對人類社會產生正面的效益，這就是資訊倫理（**information ethics**）希望達到的目標。
- ◆ 所謂的倫理（**ethics**）是指道德與是非的探討，符合倫理的行為是公認的好行為。倫理也定義了正確的價值觀，規範人類在社會生活中的權利與義務，應為與不為。在這樣的基礎上，我們就可以做價值或是好壞是非的判斷，
- ◆ 資訊倫理可以看成是資訊科技對社會產生影響以後衍生出來的探討，也可看成是各資訊專業領域中探討的倫理。

認識資訊倫理

- ◆ 倫理(ethic)指的是一個社會的道德規範系統，賦予人們在動機或行為上的是非善惡判斷之標準，是人與人之間的行為規範。
- ◆ 資訊倫理(Information Ethics) 的定義指的是應用資訊系統的倫理，亦即人在設計、操作及管理資訊系統時的倫理。
- ◆ 資訊倫理由來：Carbo(1980) 擔任美國國家圖書資訊科學委員會執行主席時，因面對許多和資訊倫理有關的議題，繼而引發她對於資訊倫理的重視。
- ◆ Johnson (1985) 首先定義資訊倫理(Information Ethics)：「應用於資訊科技及電腦使用相關的道德決策之原則。」
- ◆ 資訊倫理的觀念應具備
 - 遵守法律
 - 良好網路禮節
 - 尊重他人的隱私
 - 尊重智慧財產
 - 俱備資訊安全相關常識

資訊倫理 - PAPA

- ◆ 討論人們對資訊的態度以及行為，應用於電腦的使用、資訊科技、資訊系統、資訊網路的倫理規範。
- ◆ 資訊倫理不同於一般的法律，資訊倫理是屬於一自律、自我的約束態度。
- ◆ PAPA 理論：1986 美國梅森(Richard O. Mason)提出，包含了隱私權(Privacy)、正確性(Accuracy)、財產權(Property)及使用權(Accessibility)，成為了資訊倫理重要的主軸。



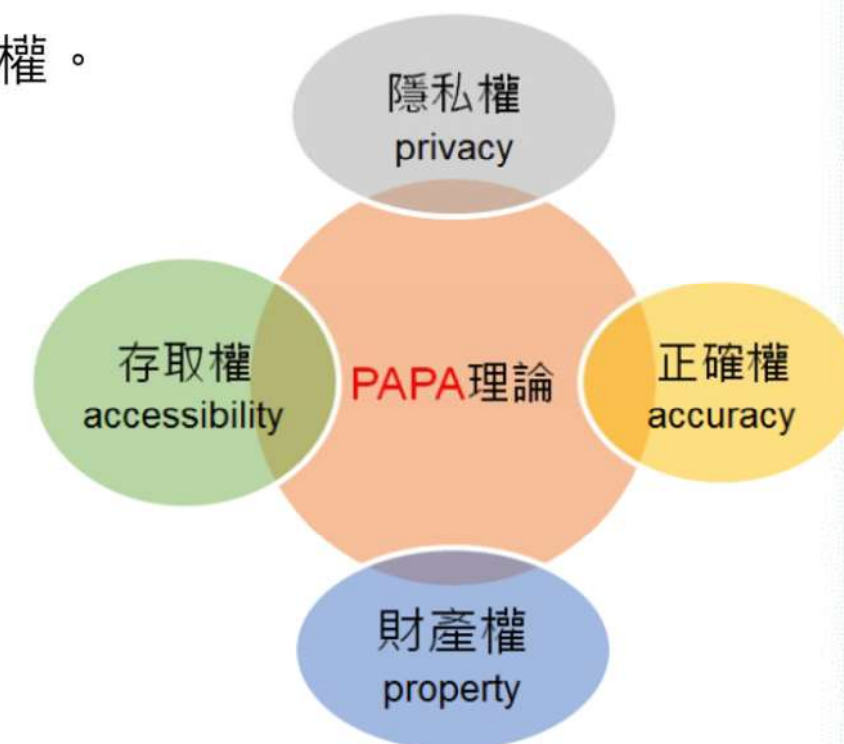
資訊倫理 - PAPA

隱私權(Privacy)

- ◆ 自然人(個人或私人)與社會公共生活無關的而不願為他人知悉或者受他人干擾的私人事項、私人生活安寧與私人資訊秘密必須依法受到保護，不被他人非法侵擾、侵犯、知悉、收集、利用和公開(爆料)的一種人格權。

正確性

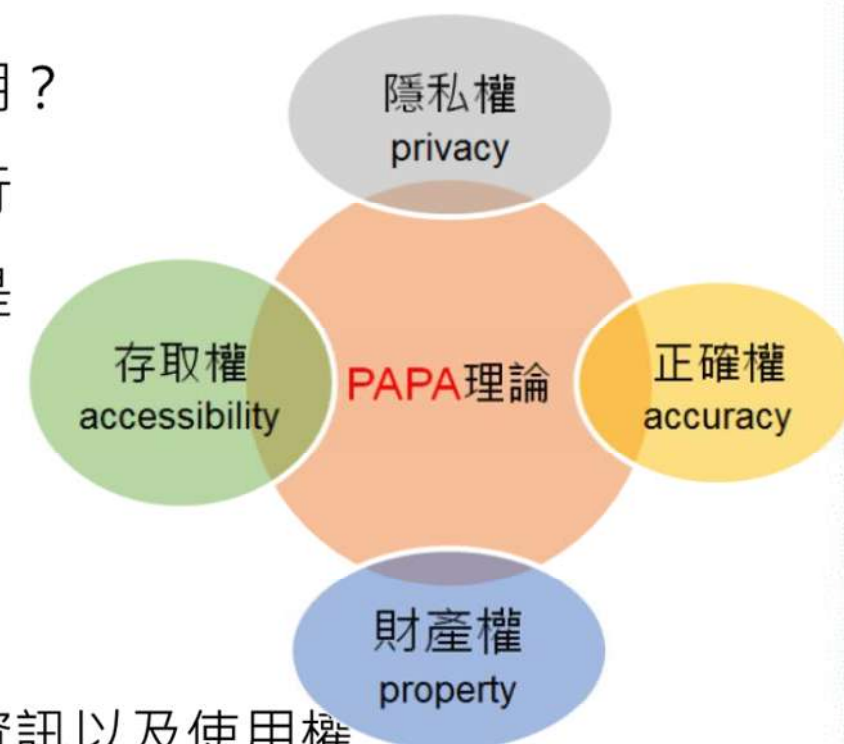
- ◆ 正確性是指使用者如何評估或確保資訊的正確性、真實性及可靠性。
- ◆ 當網站或網友之間的分享成為主要訊息來源，「正確性」就是一個重要的問題。
- ◆ 資訊使用者如何在眾多的資訊中，辨別資訊的正確性？資訊提供者如果提供或散播錯誤的資訊，負有何種責任？網站或資訊管理者如未善盡管理之責，讓資訊遭受入侵、竊取或篡改，負有何種責任？



資訊倫理 - PAPA

著作權

- ◆ 我國的著作權法對於著作權的定義，規定為：「指因著作完成所享有的著作權分為著作人格權及著作財產權」。
- ◆ 誰擁有資訊？著作權是否已讓售？資訊的價值如何評量？資訊在什麼情況下可以免費使用？什麼情況下應該付費？什麼情況下徵得著作權人的同意方能使用？什麼情況下資訊使用行為算是侵害別人的著作權？複製版權軟體是否侵害別人的著作權？網路下載破解版軟體是否侵害別人的著作權？侵害別人的著作權應負何種法律責任？



使用權

- ◆ 使用權是維護個人對資訊使用的權利，與資訊資源的控制權，且尊重和不去侵犯別人的資訊以及使用權
- ◆ 誰有權利可以取用資訊？個人和組織擁有什麼樣的資訊使用權？如何維護個人對資訊使用的權利？如何維護資訊使用的公平性？如何避免資訊「資訊貧富」的現象？如何阻檔非法入侵和電腦病毒？

認識電腦犯罪 (computer crime)

- ◆ 所謂電腦犯罪 (computer crime) 是指犯罪的目標為電腦，或是犯罪採用的手段是電腦。電腦犯罪已經存在有一段時間了，所不同的是犯罪的工具與手法。
- ◆ 入侵電腦系統、竊取線上資料，或是破壞電腦設備與資料等，都算是電腦犯罪的行為。
- ◆ 不論犯罪的方式是什麼，只要觸犯法律就是犯罪的行為，必須接受法律的制裁，電腦犯罪也是一樣。
- ◆ 在法律上一樣要針對電腦犯罪訂出適當的條文，讓電腦犯罪的判決有所依據。
- ◆ 除了資訊倫理的推行教化之外，還是需要提升一般人對於電腦犯罪的認知。

電腦犯罪的種類

◆ 從某些角度來看，電腦犯罪是有點抽象的，因為不管是電腦或是網路被癱瘓，還是資料被竊取與更改，好像都沒有比較實體的徵兆，不過電腦犯罪的影響是不可忽視的，電腦犯罪造成的損失與傷害常會因為資訊科技的特性而加劇。以下是常見的電腦犯罪種類：

- 詐騙 (fraud)
- 盜取 (piracy)
- 猥褻 (pornography)
- 非法交易
- 敲詐勒索 (extortion)
- 駭客行為 (hacking)
- 攻擊性的內容

<網路上的法律案例>：網路上公然侮辱他人

案例描述

小華在證券公司上班，因為業務關係與一位客戶發生爭執，小華氣不過，在平時常用的**網路討論區**裡頭指名道姓的辱罵這位客戶，而且使用很多不堪的字眼，小華心想反正討論區用的是別名，客戶也不一定會看到，就算是一吐悶氣吧！不料，剛好這位客戶的朋友看到，輾轉告知，本人知悉之後大發雷霆

案例分析

根據**刑法**第三百零九條第一項：「公然侮辱人者，處拘役或三百元以下罰金。」，**刑法**第三百十四條：「本章之罪，須告訴乃論。」，**刑事訴訟法**第二百三十七條第一項：「告訴乃論之罪，其告訴應自得為告訴之人知悉犯人之時起，於六個月內為之。」。所以若小華的客戶在事發6個月內提起告訴，則小華會面對嚴肅的官司

結論

以這個案例來說，小華針對特定人（指名道姓）使用不堪的字眼，已經造成對方名譽及感受上的損害，而且討論區的瀏覽者眾多，符合「公然侮辱」的條件，而小華雖然使用別名，但是帳號可以追查出來，因此小華就是貼文者，因此在法律上必須負起責任。一般人認為網路上的行為似乎不受法律約束，這是錯誤的觀念

<網路上的法律案例>：違法使用個人資料

案例描述

啟明在一所國中的教務處工作，負責學生學籍資料的管理，並且**利用電腦系統進行學籍的登錄**，剛好鄰居建民最近到一個生高中補習班打工，向啟明以一個人10元的價格購買國中學生的個人資料，包括姓名、住址與電話等資料，做為補習班招生之用。啟明心想補習班招生也不是什麼壞事，就利用工作之便**將學生個人資料燒錄在光碟上交給建民**。事後有學生家長向學校投訴接到補習班的電話與文宣廣告，懷疑學校洩漏個人資料，經調查後得知是啟明洩漏的。啟明會因為這件事受到什麼樣的法律制裁？

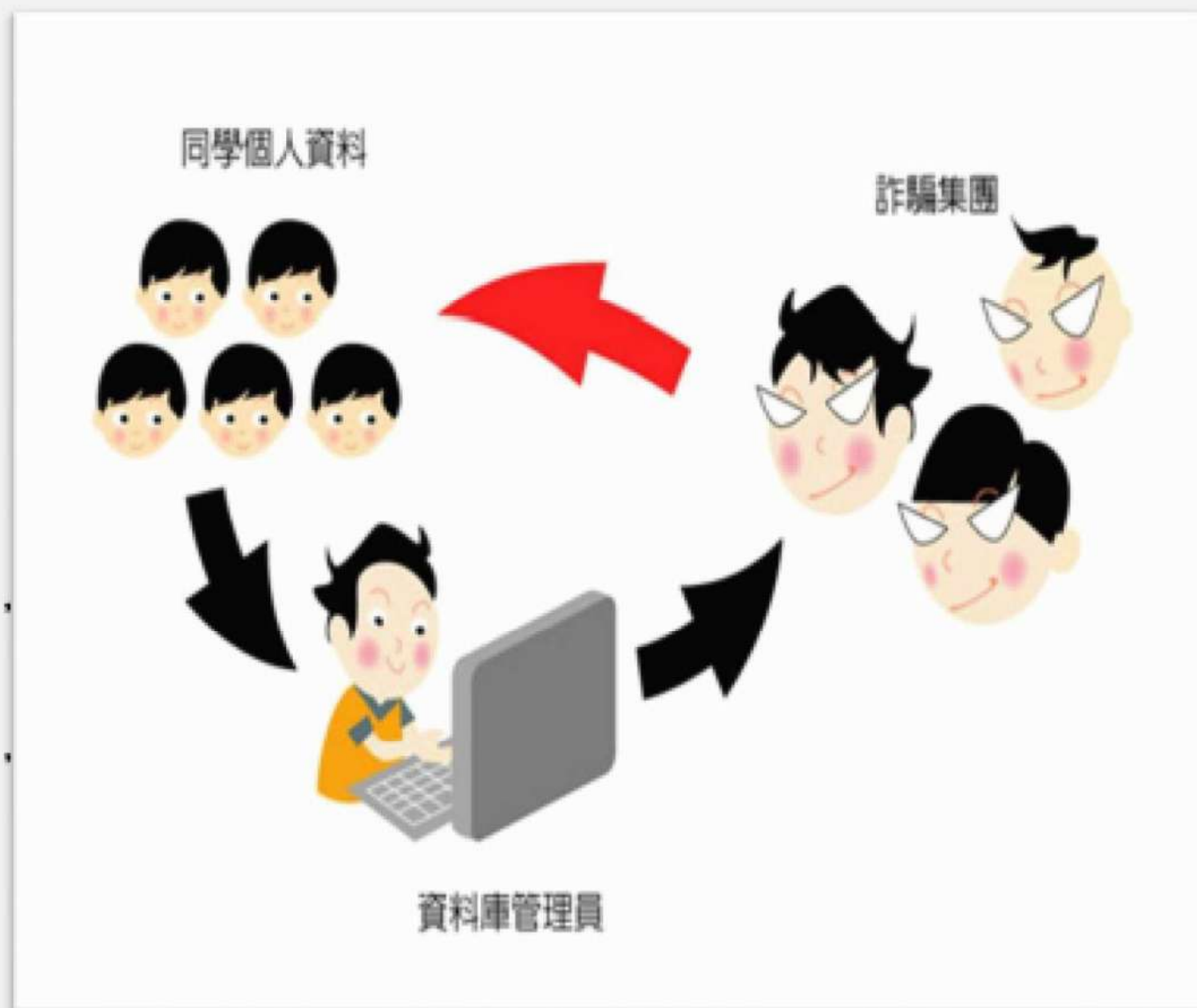
案例分析

根據**電腦處理個人資料保護法**第一條：「為規範電腦處理個人資料，以避免人格權受到侵害，並促進個人資料之合理利用，特制定本法。」所謂的個人資料可以參考電腦處理個人資料保護法第三條：「個人資料：指自然人之姓名、出生年月日、身分證統一編號、…及其他足資識別該個人之資料。…利用：指公務機關或非公務機關將其保有之個人資料檔案為內部使用或提供當事人以外之第三人。」由此看來，啟明所洩漏的確屬個人資料，所以受法律規範

<網路上的法律案例>：違法使用個人資料

結論

個人資料的使用必須在原來蒐集所規範的運用範圍之內，未經本人同意洩漏個人資料給補習班已經超過了原來的合理使用範圍。依據**電腦處理個人資料保護法**第三十八條：「有左列情事之一者，其目的事業主管機關處負責人新台幣二萬元以上十萬元以下罰鍰，並令限期改正，逾期未改正者，按次處罰之。」，所以學校未盡監督管理之職，必須負責。**民法**第一百八十四條第一項前段：「因故意或過失不法侵害他人之權利者，負損害賠償責任。」**民法**第一百八十八條第一項前段：「受僱人因執行職務不法侵害他人之權利者，由僱用人與行為人連帶負損害賠償責任。」所以按照民法的規定，只要當事人提出告訴，學校與啟明都必須負連帶的法律責任



個人資料之定義與範圍

個人資料：指自然人之姓名、出生年月日、國民身分證統一編號、護照號碼、特徵、指紋、婚姻、家庭、教育、職業、病歷、醫療、基因、性生活、健康檢查、犯罪前科、聯絡方式、財務情況、社會活動及其他得以直接或間接方式識別該個人之資料。。

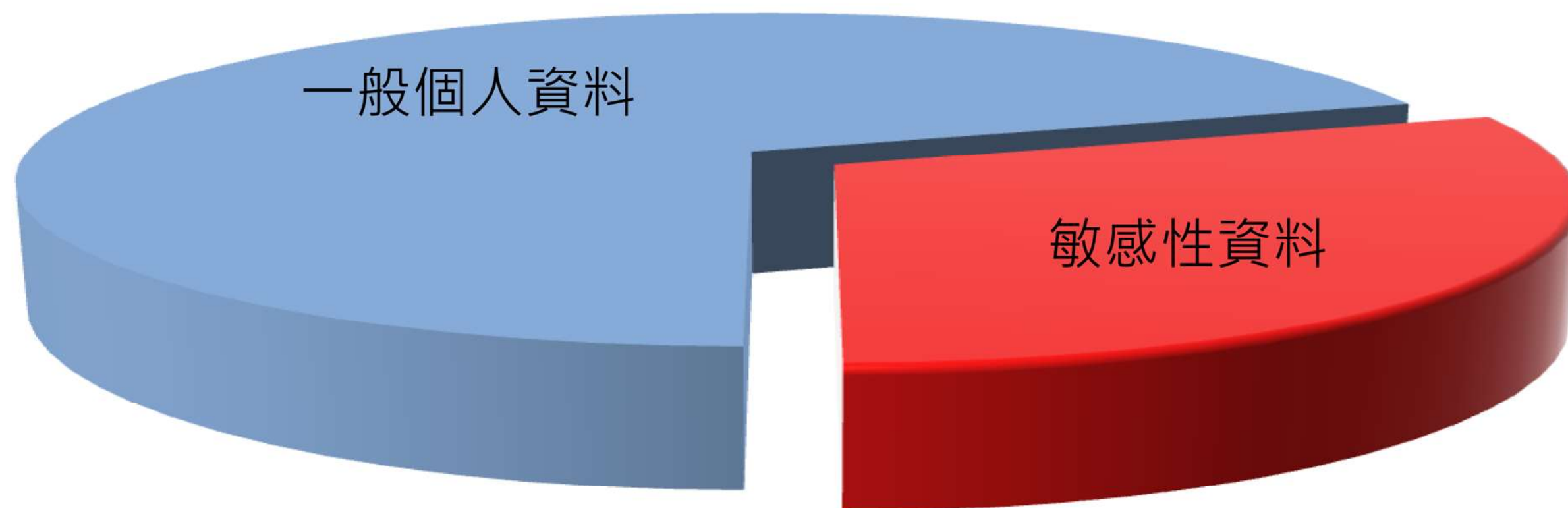
以間接方式識別該個人之資料，指僅以該資料不能識別，須與其他資料對照、組合、連結等，始能識別該特定個人者。

個人資料檔案包括備份檔案

在規範地區的部份，只要是具有中華民國國籍的自然人，個人資料不論在境內或境外，皆受此法保護

個人資料之定義與範圍

- ◆ 區分「一般性個人資料」與「敏感性個人資料」。



個人資料之定義與範圍

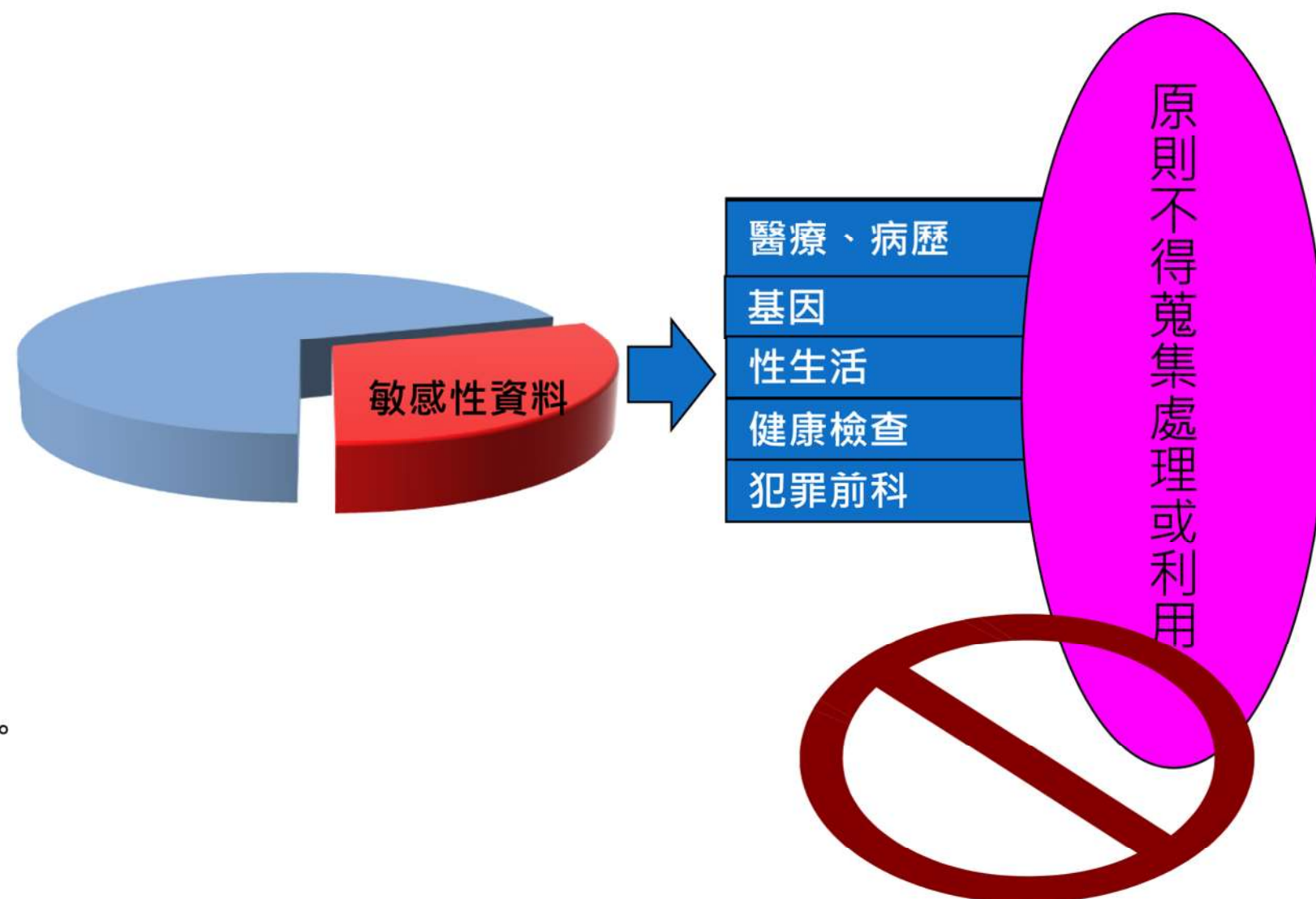
◆ 敏感性個人資料：

➤ 醫療、基因、性生活、健康檢查及犯罪前科

➤ 原則：不得蒐集、處理或利用

➤ 例外：

- 法律明文規定。
- 公務機關依法或非公務機關履行法定義務所必要。
- 當事人自行公開或其他已合法公開者。
- 公務機關或學術研究機構基於醫療衛生或犯罪預防目的。



個人資料當事人之權利

◆個人資料當事人之權利

當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制：

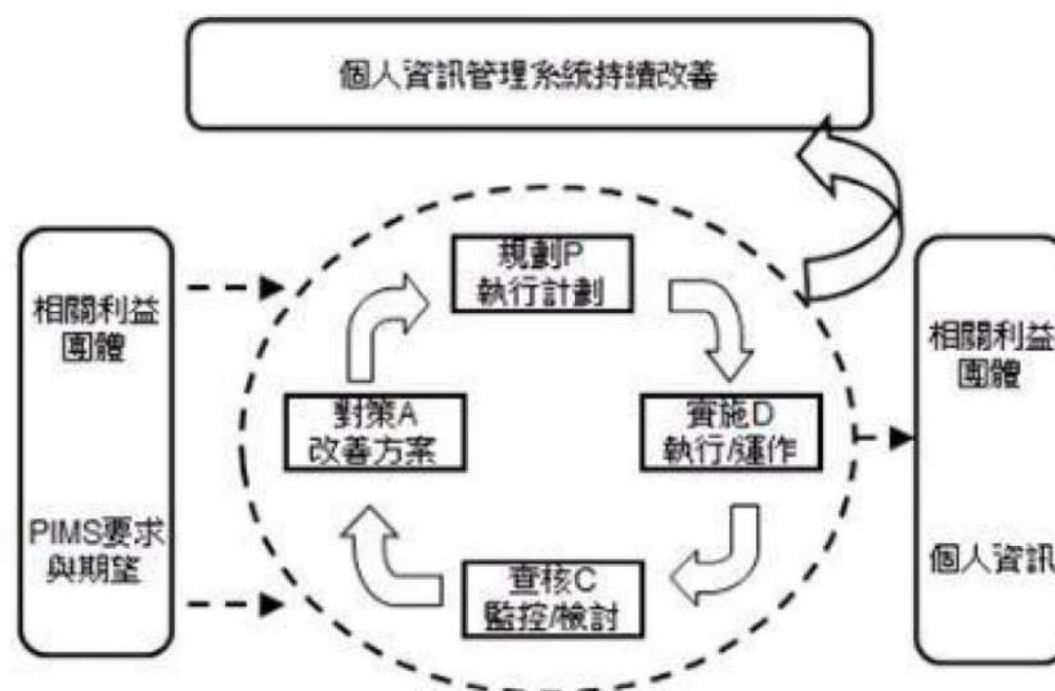
- 一、查詢或請求閱覽。
- 二、請求製給複製本。
- 三、請求補充或更正。
- 四、請求停止蒐集、處理或利用。
- 五、請求刪除。

個人資訊管理系統(PIMS)

- ◆ BS10012PIMS由英國標準協會基於OECD、APEC及資料保護法對於個人資訊管理制定而來。
- ◆ BS10012與其他國際標準一致，定義了個人資訊管理系統(Personal Information Management System, PIMS)的要求。
- ◆ 採用過程方法來建立、施行、運作、監控、審查、維護及改善組織的個人資訊管理系統(PIMS)。
- ◆ BS10012除針對資通訊(ICT技術)的標準要求，亦從法律，面、管理面與流程面對於個人資訊的管理，在符合國內個人資料保護法及組織所應遵循產業之最佳實務要求下，進行保障組織所持有之個人資訊。



榮獲英國標準協會驗證



個資管理 - PDCA方法論



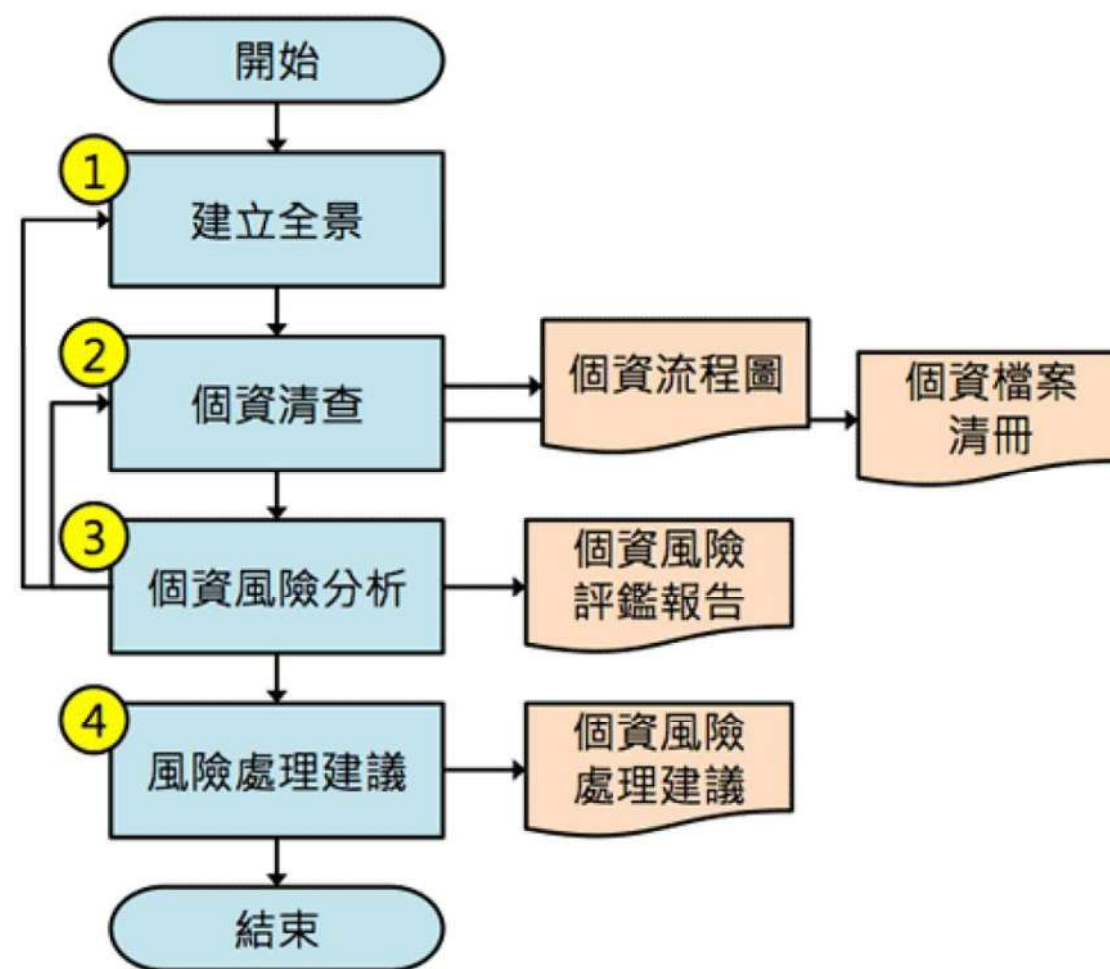
個資清查

◆ 清查組織內的個資

- 透過管理面的盤查方式：擁有者填報與造冊。
- 透過搜尋檢索技術：全文檢索功能的工具。

◆ 去個資化/去識別化

- 不影響作業的前提下，儘量把個資資料去個資化。
- 也就是刪除或分割資料，讓資料不再具有個資的特性，達到保護的目的。



GDPR 歐盟通用資料保護規範

- ◆ GDPR (EU General Data Protection Regulation) 中文翻作《通用資料保護規範》，是在歐盟法律中對所有歐盟個人關於資料保護和隱私的規範。歐盟早在1995年就制定了《個人資料保護指令》(Data Protection Directive)，不過當時並不普及，也只是一項「指令」。
- ◆ 隨後，歐盟在2016年4月27日通過了GDPR法案，2018年5月25日正式生效，這就是一項大家都必須遵循的「規範」、「法規」了。簡單地說，GDPR就是歐盟的個資法。
- ◆ 不管是法人或自然人、大公司、小公司，只要跟歐洲民眾有牽扯到關係，就必須符合GDPR通用資料保護規範。
- ◆ 台灣地區定義的個人資料為姓名、性別、電話號碼、住址、身分證字號……等。
- ◆ GDPR則擴展到可直接或間接查詢到特定對象的資料，包括基因、生物特徵、醫療資料、個人使用瀏覽器時的 Cookie、IP位址、行動裝置ID、社群網站活動紀錄……等。

GDPR 歐盟通用資料保護規範

◆ 個人資料定義

- 能辨識出一個人的任何資料，加上個人在網路上的相關資料。
- 台灣地區定義的個人資料
- Cookie
- IP位置
- 行動裝置ID
- 社群網站活動紀錄

◆ 個人資料當事人的權利

- 更正權
- 刪除權
- 個資可攜權
- 拒絕權



GDPR 歐盟通用資料保護規範

規範對象	對歐盟境內人民提供商品、服務、客戶中有歐盟公民、雇用歐盟員工
個資定義	包括電話號碼、地址、行動裝置ID、社群網站等，會暴露個人身份的資料，以及血統、政治意見、宗教、生物特徵、性傾向等個人特徵都算
當事人權利	更正權、刪除權、個資可攜權、拒絕權
企業責任	知悉個資遭侵害，需72小時內通報與通知、個資保護影響評估、個資保護設計及預設

GDPR 歐盟通用資料保護規範

歐盟通用資料保護規則GDPR章節概覽

章節條文	內容概要
第一章、總則 (第1條~第4條)	說明修法的目的、個人資料適用範圍、適用區域，及GDPR引用名詞各項定義，包括個資；處理；限制處理；剖析；擬置名化；資料控制者；資料處理者；資料接收端；第三方；資料外洩；遺傳基因；生物特徵等。
第二章、原則 (第5條~第11條)	說明當事人個資處理的6大原則，處理合法性的成立條件；當事人的同意要件；處理兒童、特種個資，及犯罪記錄等個資處理原則；以及經資料控制者處理不允許識別自然人去識別化要求等。
第三章、當事人權利 (共5節，第12條~第23條)	確保資料主體的法定權利，分成5節，分別包含：透明性和形式；資訊與資料主體近用權；限制處理和刪除要求；反對權與剖析；以及限制權等定義。
第四章、控制者與處理者 (共5節，第24條~第43條)	分別定義：一般性義務；個人資料安全；資料保護影響評估與事前向主管機關諮詢與授權要求；資料保護長設計與責任；行為準則與認證或標準驗證機制。
第五章、個資跨境傳輸 (第44條~第50條)	說明個資傳輸到歐盟以外第三國或國際組織時的要件，包含傳輸時的一般性限制、事前評估和傳輸過程保護等。
第六章、獨立監督機構 (第51條~第59條)	說明各會員國設立個資監管專責機構的功能、權責與要求，保護歐盟境內有關個資處理和促進個資的自由流通的自然人之基本權利和自由，歐盟各國需成立至少一個專責機構監督一般個資保護規章的落實情形，且各會員國的專責機構和歐盟執委會間，需保持合作關係。
第七章、監管機構協同合作與一致性 (第60條~第76條)	確保個資保護規章具備實施的可行性及實施上的一致性，各會員國設立的個資監督管理專責機構需互相提供重要資訊和協同合作，定義歐盟通用資料保護規則的實施，及說明歐洲資料保護委員會的組成。
第八章、法律救濟、損害賠償與罰則 (第77條~第84條)	說明歐盟通用資料保護規則向各會員國設立的個資監管專責機構的申訴權利，與個人資料監督管理專責機構、個資控制者、個資處理者對抗時的司法救濟、損害賠償及刑責與行政裁罰等。
第九章、對特定情況處理規章 (第85條~第91條)	針對個人表意自由、醫療、勞工雇主僱傭關係、學術研究及宗教等議題下的個資處理規範。
第十章、施行細則 (第92條~第93條)	說明歐盟通用資料保護規則的授權行號及執委會的定位與程序。
第十一章、附則 (第94條~第99條)	說明對原本歐盟個資隱私保護指令及電子通信隱私保護指令的廢止，歐盟執委會考核，及GDPR公告生效與制式施行日期。

資料來源：臺灣BSI、臺灣勳業策略、iThome整理，2017年9月

★ 歐盟通用資料保護規則 ★ GDPR十大重點

- 重點1** 以資料為主體，明年5月正式實施
- 重點2** 企業必須設置資料保護長，且需負起法律責任
- 重點3** 個資的蒐集、處理和利用，必須先徵求當事人的同意
- 重點4** 強化個人資料可攜權權利
- 重點5** 新增被遺忘權
- 重點6** 外洩個資，必須在72小時內通報資料保護主管機關
- 重點7** 個資保護系統預設要納入隱私保護
- 重點8** 賦予當事人有權反對被自動化剖析 (Profiling) 權利
- 重點9** 要求企業必須落實資料保護影響評估
- 重點10** 提高罰則金額，甚至以全球營業額計算罰金金額

資料來源：iThome整理，2017年9月

GDPR 歐盟通用資料保護規範

◆ 被遺忘權(Right to be forgotten)

- 是一種在歐盟已經付諸實踐的人權概念
- 可以要求控制資料的一方，刪除所有個人資料的任何連結(link)、副本(copies)或複製品(replication)

◆ 資料可攜權(Right to data portability)

- 意思是用戶可以將A服務的資料，轉移到B服務上。
- 例如：Instagram的資料打包備份功能；蘋果推出管理個資工具。



智慧財產權

- ◆ 智慧財產權，Intellectual Property Rights，簡稱「IPR」，是人類智慧創造出來的無形的財產。
- ◆ 主要涉及版權、專利、商標等領域。·音樂和文學等形式的藝術作品，以及一些發現、發明、詞語、詞組、符號、設計。
- ◆ 分為工業產權與版權兩類，工業產權包括發明(專利)、商標、工業品外觀設計和地理標誌，版權則包括文學和藝術作品。



智慧財產權				
市場相關	客戶相關	產品設計相關	合約相關	技術相關
-註冊商標 -企業名稱或產品/服務品牌 -未註冊之商標及設計(如副品牌、人物名稱) -網域名稱(如TLD、SLD) -QR code	-資料庫權利(如客戶資料) -著作(如軟體) -機密資訊(如客戶名單、特定產品之窗口、報價) -提供服務的方法	-網頁設計 -產品設計 -音樂、廣告詞 -著作(如手冊、網頁內容、教育訓練材料) -圖片及照片 -剪報及視聽材料	-消費者條款和條件，包含退貨政策 -使用第三人智慧財產之授權(如app、網頁設計) -供應商合約(如權利分配原則) -NDA	-新發明 -演算法(如用以分析客戶資料) -軟體-目的碼和原始碼(如銷售平台、apps) -網頁搜尋工具 -營業秘密、程式 -商業方法和系統

智慧財產權相關規定

臺灣智慧財產相關規定

	申請/登記	保護年限	排他性	是否須公開	侵權是否有刑責
專利權	須申請，並經過審查	發明20年 新型10年 設計12年	有	申請後18個月後須公開	無
商標	須申請，並經過審查	公告當日起10年（可展延）	有	註冊公告	有
營業秘密	不需申請登記	通常無限制	有（但無法排除他人獨立開發）	不得公開	有
著作權	不需申請登記，創作完即受保護	發行後50年（法人）	有（但無法排除他人獨立開發）	不需要，但通常會公開發表	有

專利權

◆ 「專利」是專利權的簡稱，為專有之利益及權利，國家授與發明人在一定時間內享有排他性之製造、利用、販賣該項發明的權力

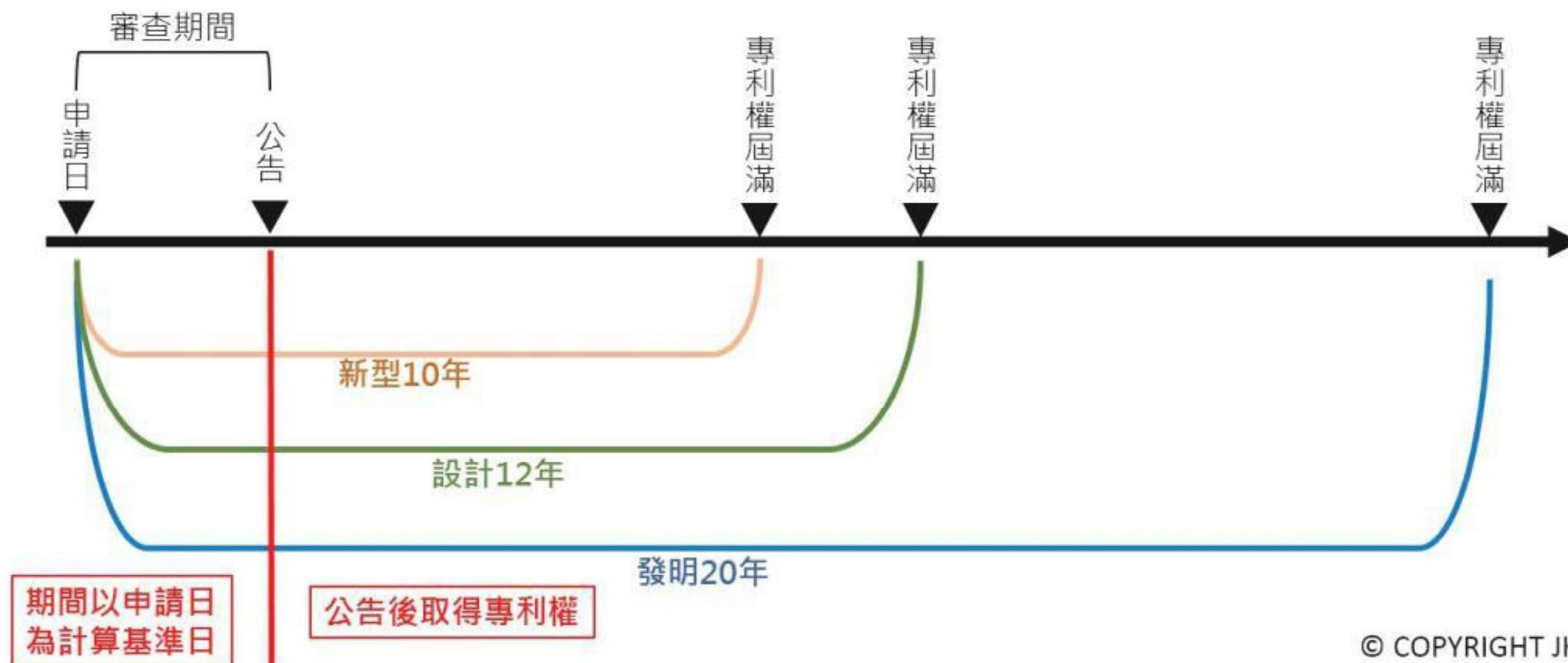
◆ 特點

- 專有性或排他性：權利人享有佔有、使用、收益和支配的權利。其他人未經權利人許可，不得利用此權。
- 地域性：權利人享有的權利，只有在核准該權利所屬的領土有效。美國的專利在台灣領土上無效。
- 時間性：除商標可依法延展外，專利權都有一定的期限。法律規定的期限屆滿以後，專利權即告終止。



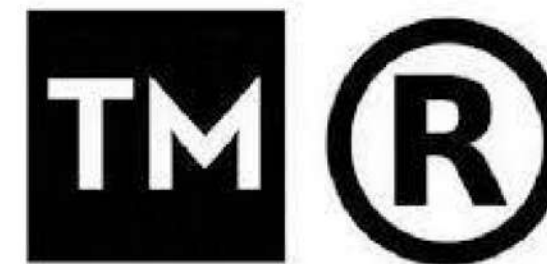
專利權

專利權期間



商標法

- ◆ 商標專用權的簡稱，是指商標使用人依法對所使用的商標享有的專用權利。
- ◆ 商標註冊人依法支配其註冊商標並禁止他人侵害的權利，包括商標註冊人對其註冊商標的排他使用權、收益權、處分權、續展權和禁止他人侵害的權利。
- ◆ 商標權可以分解為
 - 占有權：我國需申請在先，並獲准註冊。(但部分國家只要證明先使用即占有)
 - 使用權：排他性，未經所有人許可，不得在相同或類似商品使用
 - 收益權：可透過合約，許可他人使用，而取得代價(收費)
 - 處分權：轉讓、贈予、放棄

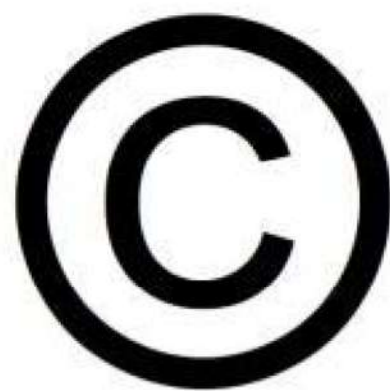


中華信託集團



著作權

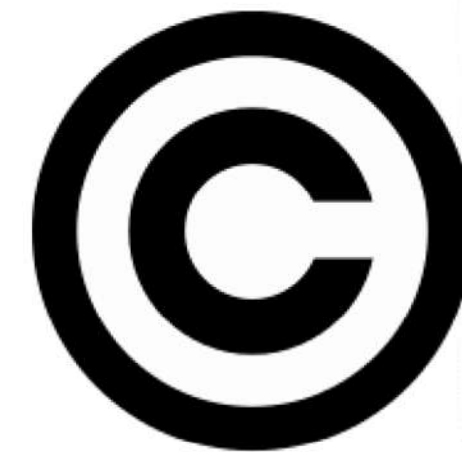
- ◆ 在我國，「著作權」與「版權」為同一法律概念。
- ◆ 是指文學、藝術、科學作品的作者依法對他的作品享有的一系列的專有權。
- ◆ 著作權是一種特殊的民事權利，也包括法律賦予表演者、音像製作者廣播電臺、電視臺或出版者對其表演活動、音像製品、廣播電視節目或版式設計的與著作權有關的權利。
- ◆ 著作權是在作者的作品創作完成之後，即依法自動產生，而不需要經過任何主管機關的審查批准。



copyright

all rights reserved

著作權法符合正當引用要件



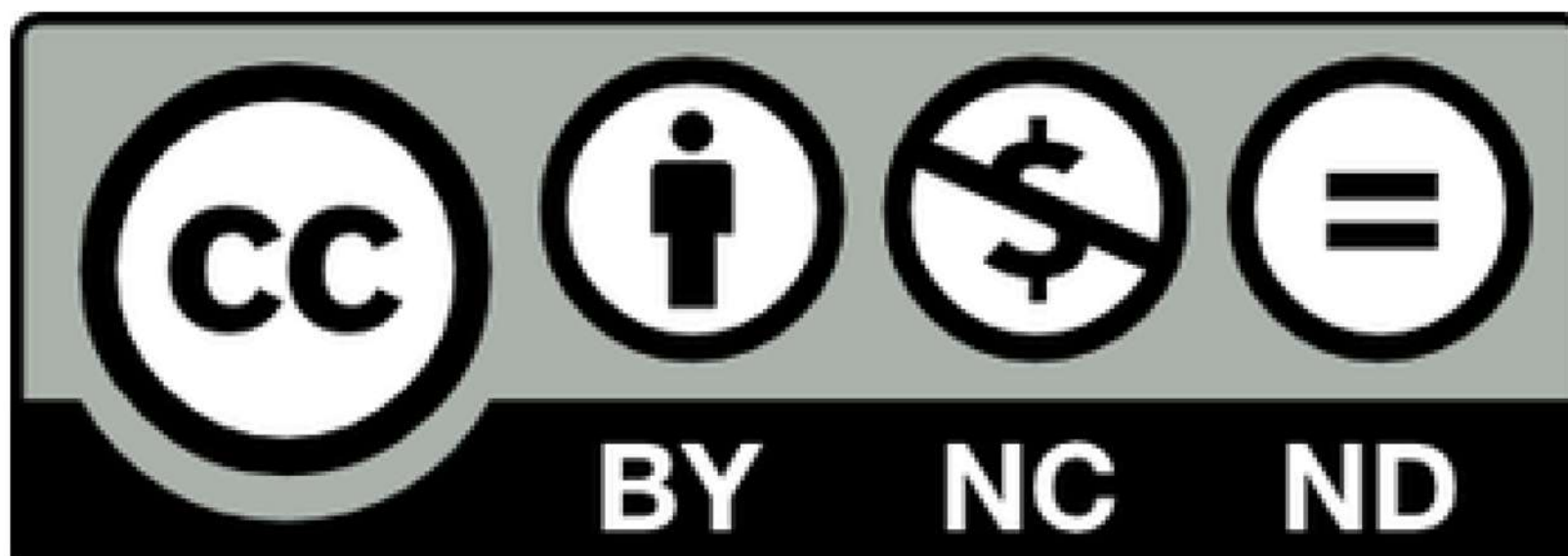
依據著作權法，引用他人著作必須符合以下的要件，才能主張構成合理使用，而不致侵害他人的著作權。

- ◆ 須為報導、評論、教學、研究或其他正當目的之行為
- ◆ 須有「引用」之行為
- ◆ 須在合理範圍內
- ◆ 被引用之著作須已公開發表
- ◆ 須明示出處



創用 CC (Creative Commons)

- ◆ 創用CC(Creative Commons)是一個非營利的組織，致力於讓各種創作內容能在合法的情況下更有彈性地分享。
- ◆ 創用CC的授權(Creative Commons licenses)可以明確地區分哪些是原創作者保留的權利、哪些是原創作者願意為了分享而不主張的權利。
- ◆ 傳統的版權宣示常看到所謂的「All rights reserved.」的字眼，也就是保留所有的權利性，有關於創用CC的授權要素與授權條款可參考下列網站的內容(<http://Creative Commons.tw/>)



創用 CC 的四個授權要素



姓名標示表示：必須按照著作人或授權人所指定的方式，表彰其姓名



非商業性表示：不得因獲取商業利益或私人金錢報酬為主要目的來利用作品



禁止改作表示：僅可重製作品不得變更、變形或修改



相同方式分享表示：若變更、變形或修改本著作，則僅能依同樣的授權條款來散布該衍生作品

電子資料蒐集之安全威脅

◆ 未落實資料分級

- 電子檔案未依分級受妥善防護，導致資料外洩、遭竄改或毀損。
- 發生資安事故後，不易追蹤來源與釐清責任，並行補強矯正措施。

◆ 引用不當資料

- 所蒐集而得之資料不當，導致電子檔案內容發生謬誤。
- 蒐集之資料未獲授權，侵害他人版權。
- 不當使用個人隱私資料，違反個資法。

電子資料處理之安全威脅

◆ 資料外洩

- 檔案遭列印為紙本流出。
- 駭客透過軟體的暫存檔案進行資料竊取。

◆ 資料毀損

- 編輯作業操作疏失，導致資料遺失。

◆ 資料內容錯誤

- 人為操作的疏忽導致內容不正確。
- 檔案未進行版本管控，缺乏追蹤修訂紀錄，發生錯誤後，不易修補。

電子資料處理之防護

- ◆ 於電腦中安裝暫存檔清除工具，可減少資訊殘存問題之發生。
- ◆ 確認雲端儲存的資料在合約終止後是否完全清除。
- ◆ 文件管理系統具有良好的版本管理功能。
- ◆ 存取權限管理：
 - 透過相關工具軟體
 - 遵循「最小揭露原則」，僅供存取職務所需之最少資料
- ◆ 稽核工具：
 - 記錄使用者的存取行為
 - 嚇阻非授權存取與具有權限人員進行不合理之非法存取
- ◆ 防範內賊。

稽核查核目的

- ◆ 優良管理系統不在於達到100%零缺失，而是具備不斷持續改善的能力(PDCA)。
- ◆ 驗證是否符合規定的要求。
- ◆ 評估管理系統之實施有效性。
- ◆ 為管理審查提供相關資訊。
- ◆ 加強整體安全意識。
- ◆ 降低管理系統失效的風險。
- ◆ 提供管理系統改善之機會。



稽核基本概念

稽核



係指一個有能力且獨立的人員，以系統化程序方式來執行，主要目的為取得及評估有關經濟個體或事件之證據，以支持表示意見及提出符合準則報告之確認性聲明。

稽核步驟



經過適當規劃、全面性風險評鑑、研擬稽查工作底稿、收集證據、依證據評估控制強弱及準備稽查報告（以客觀地態度表示意見予管理當局）、適當的資源與時程來執行後續追蹤。

稽核類型

稽核類型



1 >

第一方稽查（內部稽查）

組織對自己之業務流程進行稽查



2 >

第二方稽查（外部稽查）

為主管組織對下屬或同儕，如：組織
對其委外廠商之業務流程進行稽查



3 >

第三方稽查（驗證稽查）

由獨立驗證組織（如BSi）對組織業務
流程進行稽查工作

稽核員基本原則

- ◆ **道德行為**：資安稽查工作各方面，都應盡職業上應有之注意，及遵循職業道德規範及專業稽查準則。
- ◆ **專業**：稽查人員應具有資訊安全與之認知、執行稽查工作之技巧及知識，藉由充分且持續之專業教育訓練，以維持其專業技術能力。
- ◆ **謹慎客觀**：稽查人員對於稽查所見應保持客觀、謹慎求證之態度。
- ◆ **獨立性**：稽查人員對於涉及稽查之任何事項，在態度及言行表現及實質(需兼顧組織及職能)上皆應獨立於被稽查部門(或人員)。
- ◆ **證據**：藉由蒐集並評估證據的過程，以決定是否達成目標。



稽核之職責

- ◆ 稽查工作準備
- ◆ 遵守組織要求
- ◆ 維持獨立性及保密
- ◆ 執行與完成稽查
- ◆ 維護稽查紀錄
- ◆ 及時報告稽查結果



Q&A

資產與風險管理

資產分類分級與盤點

風險評鑑與風險處理

資訊資產項目

1. **實體資產**：所有電腦設備、通信與網路設備及相關週邊設備等
2. **軟體資產**：自行或委外開發之軟體、套裝軟體、公用程式等
3. **電子資訊資產**：電子儲存之文件、系統資料、組態設定檔、稽核紀錄檔等
4. **書面文件**：書面管理文件與紀錄、系統相關文件等
5. **服務**：通訊、網路、照明、電力等
6. **人員**：正式職員、約聘人員、廠商駐點人員及工讀生等

資訊資產蒐集與管理

硬體、軟體、資料、紙本、人員

蒐集資訊資產清冊

將資訊資產依其特性
進行分類/群組

分類
群組

實做控管

依不同分類/群組進行不同管控
Ex：核心重要設備必須建置備援
Ex：內部機密資料不得任意複製

管理
機制

- 應維持資產清冊的**正確性**
- 設計資訊資產清冊的**更新流程**

資訊資產清冊

資訊資產清冊範例

機密等級： ☐ 一般 ☒ 限閱 ☐ 密 ☐ 機密							
資訊資產清單							
文件編號：							
記錄編號：							
資產編號	資產類別	資產名稱	資產說明	權責單位	保管單位	使用單位	資產價值

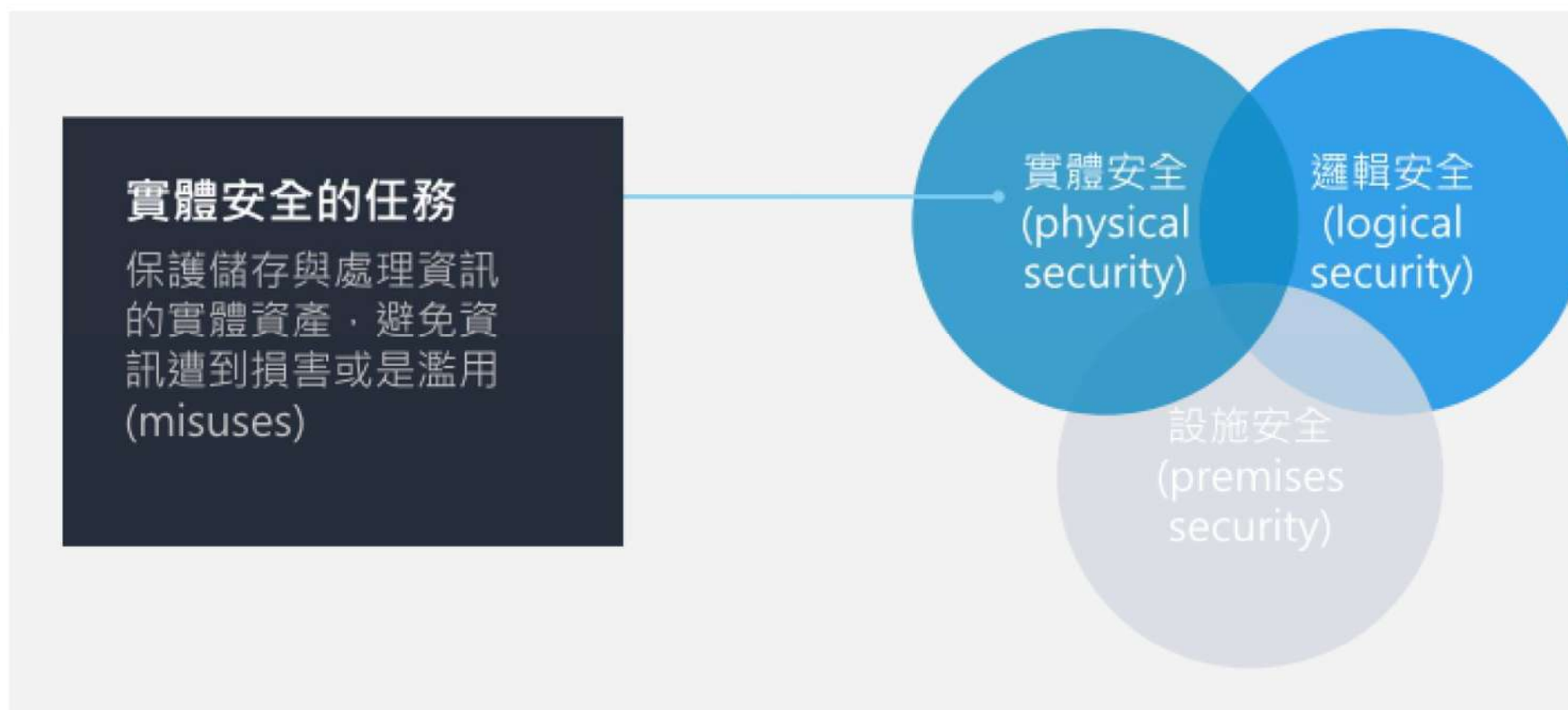
資訊資產價值分類

資訊資產價值分類

資訊資產價值與其潛在影響等級之對應		
級別	資訊資產價值分類內容	潛在影響等級
A級	違反資訊安全保護政策，會對 國家安全 之重要機敏資訊或系統等造成工作營運停頓或嚴重之損害，影響 業務推動持續一個月(含)以上 之損害。	極高度
B級	違反資訊安全保護政策，會對 社會秩序、民生體系運作及民眾隱私 之機敏資訊或系統，影響業務推動 持續一星期(含)以上 之損害。	高度
C級	違反資訊安全保護政策，會對 地方縣市級之社會秩序、人民生命財產 之重要資訊或系統，影響業務推動 持續一天(含)以上 之損害。	中度
D級	違反資訊安全保護政策，造成意外的事件不影響業務工作或營運。	低度

資訊系統安全的三個主要元素

- ◆ **實體安全(physical security)**：以防制實體入侵來保護資訊系統
- ◆ **邏輯安全(logical security)**：保護電腦資料免受軟體或通訊方面的威脅。
- ◆ **設施安全(premlises security)**：保護特定區域內人員與財產的安全



資訊系統安全的三個主要元素 - 實體安全威脅

- ◆ 在探討任何保障實體安全的作為之前，應該先了解有哪些實體安全的威脅。
- ◆ 實體安全威脅的類型
 - **環境的威脅**：因為環境狀態的改變而造成的威脅，例如自然災害。
 - **技術的威脅**：特別指電力或是電磁干擾引發的威脅，會對資訊系統造成危害。
 - **人為的威脅**：最難處理與預料的威脅，通常會突破預防的措施，專攻弱點。

實體安全計畫規劃流程

- ◆ 實體安全計畫是規劃保護實體安全作為的第一個步驟，目標是偵測出實體的威脅，嚇阻防止入侵，透過延遲的措施來降低損害。發生事故時能立即評估並有相關的通報與處理程序。



內部的支持系統

- ◆ 實體環境固然要有適當的保護，還是需要其他的日常設施的正常運作才能確保安全，例如電力、水與空調等設施。
- **電力**：可以分成主要電力來源與次要電力來源，當主要電力來源中斷時，次要電力來源須供電，如發電機。
- **環境控制**：水電、瓦斯與空調等應熟悉緊急開關，並能透過環控系統發出通知警訊。
- **空調**：調節溫度與濕度，安全區域應維持正風壓，要有獨立的電力供應線路。
- **火災**：應了解火的組成，考量滅火的方式，最好導入自動火災偵測，設置滅火設備。

周邊安全(perimeter security)

01 設施門禁

最基本的管制

不能讓設施任由任何人或物進出，要有實體與技術的控管，並且能做到監控與記錄

02 人員進出控管

辨識與驗證

對於進出的人員要能識別，並且做進一步的驗證。現代的技術有很多可靠有效的選擇

03 周邊保護機制

多元化的堅固防禦

盡量避免或是拖延非法的入侵，除了傳統的圍牆之外，監視系統與感測裝置都有可能派上用場

04 入侵偵測

偵測改變

透過自動感測改變能及早發現入侵的事件。實體安全的入侵偵測須部署適當的裝置

建立實體安全環境

- ◆ 資訊系統也涵蓋了所在的環境以及其中的資料與使用者，環境本身的建置必須考量能保護相關的內涵。
- ◆ 安全的實體空間：進行實體隔間時應注意到空間的安全防護能保護裡頭的資訊資產，在空間的設計上須對各組成項目進行安全的評估與建置，要以專業的角度詳盡地設計。
- ◆ 天花板要考量承重與防火的程度，若無法承重或是不牢固，容易造成人員與資產的危害。
- ◆ 牆面應考量防火與堅固程度，也要注意儲存媒體存放地點的防火要求更高，地板也要考量承重與防火程度。
- ◆ 門要考量堅固程度，避免被輕易破壞入侵，緊急出口要淨空，緊急狀況下要維持開啟。
- ◆ 窗戶要考量被破壞與入侵的可能性，機房一般不會設置窗戶，一定要裝時要採半透明以及強化玻璃。

安全區域設計

- ◆ 規劃實體區域時應該依照不同的安全等級來劃分區域，通常會把區域分成「控管」、「限制」、「公開」，或是「機敏」，然後依照安全等級來規劃適當的安全控制措施。
- ◆ 區域規劃圖應該標示出各區域的安全要求等級，常見的安全區域包括電腦資訊設備機房、電力機房等。
- ◆ 各安全區域應安裝適當的安全偵測器、煙霧偵測器應安置於天花板的下風處，通風口應加裝鐵網。
- ◆ 安全等級高的安全區域須採用強度高的牆面，而且要確認由建物樓地板連接到天花板。
- ◆ 滅火器應安置在容易取得的地方，安全要求高的區域要盡量防止不法的入侵。

門窗的安全

- ◆ 門應依照疏散方向**向外順向開啟**。門的設定在 **fail safe** 的情況下，平時上鎖，火災時應保持開啟，適用於有人員作業的區域。
- ◆ 門的設定在 **fail secure** 的情況下，平時應上鎖，火災時保持關閉狀態，確保物品安全，適用於無人的倉庫區域。

實體設施的控管

- ◆ 實體的進出口需要控管，例如大門、側門、緊急出口，或是車輛貨物的進出，應做適當的識別，要注意尾隨進出的情況。
- ◆ 實體設施可建置監視錄影，可進一步地做動作偵測、身份識別，確保監視系統的安全，並應妥善保存錄影資料。
必要時可與其他安全系統整合。

空調系統

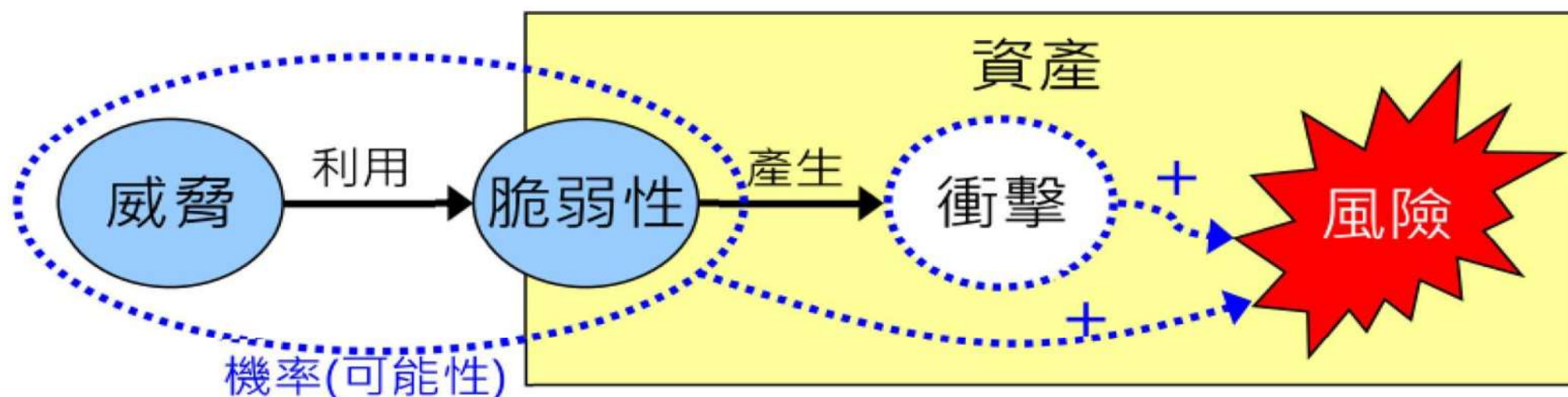
- ◆ 須確認空調系統的功能，以便進行空調系統的規劃，安全區域應保持正風壓，開門的時候風要往外吹送，使煙霧或是有毒氣體往外流。
- ◆ 濕度不宜太高，避免設備生鏽，但是濕度太低會容易產生靜電，一般會控制在 40%~60%。
- ◆ 應透過換氣保持空氣新鮮流通，保護進氣口，防止污染進入，應能自動偵測煙幕。
- ◆ 應採用獨立的電力供應線路，這樣才不會與其他系統的電力需求相衝突。
- ◆ 清楚地記載維修紀錄，確認設施有定期保養，並應描述維護的程序。

緊急應變程序

- ◆ 建立了緊急應變程序才能在緊急的資安事件發生時，遵循標準的作業程序，知所為知所不為。
- ◆ 緊急應變程序：應該建立清楚的文件，放置在容易取得的地方，對於緊急事件發生時的處理有詳細的描述，必要時須定期更新，確實反映最新的狀況。
- **緊急關機程序**：假如狀況要求進行關機，必須知道遵循什麼步驟進行關機。
- **人員疏散程序**：人員須疏散時，應該遵循的標準程序，包括疏散的引導與分工。
- **人員認知訓練**：透過訓練讓人員建立緊急應變的基本認知，能在狀況發生時按照程序運作。
- **消防演習**：透過演習確認消防設備的正常運作，以及人員的操作技能。

風險的定義

- ◆ 很多領域都會討論風險(risk)，在規劃資訊安全的相關作為之前，應該先評估資訊安全的風險。
- ◆ 「風險」是指「威脅」利用其相對應「脆弱性」直接或間接造成組織一個或一群「資訊資產」受到「衝擊(Impact)」的「可能性」。
- ◆ 風險透過「**衝擊**」與其「**可能性**」兩個因素的結合來定義其影響程度或損害程度。
- ◆ 風險管理的目標：在最低的防護成本投入下，獲得最優化的安全性(注意最優化非最強固，而是最合適)。



風險的定義

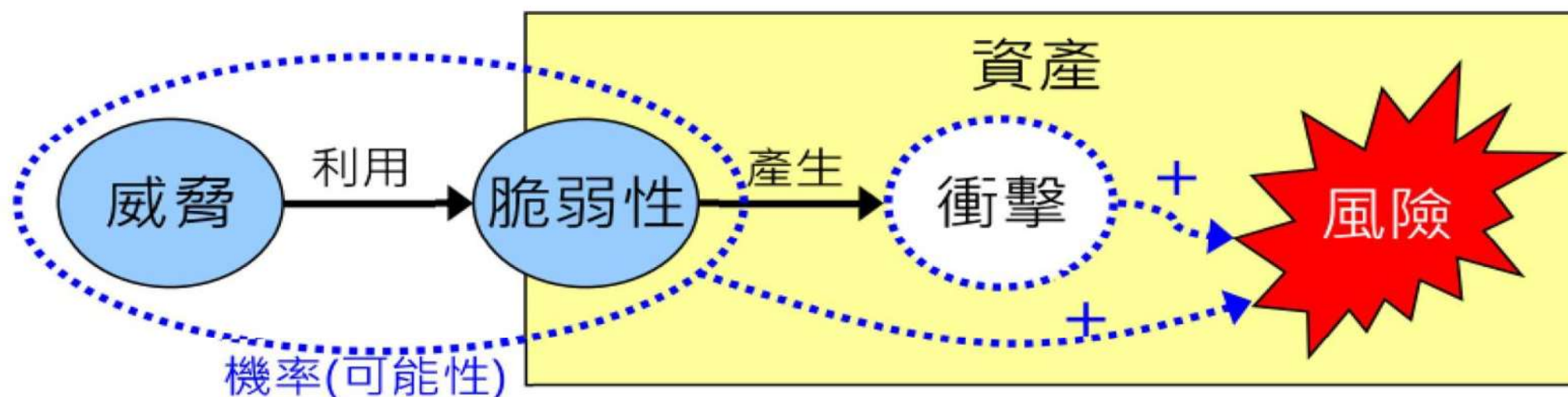
◆ 根據 ISO31000:2018 的標準，風險是指對於組織目標產生的不確定影響。風險使實際的結果與預期的結果不同。

這裡所稱的組織適用於各種類型與大小的機關。

◆ 組織目標：一個組織的目標可能包括好幾個面向，是組織運作的主要目的。

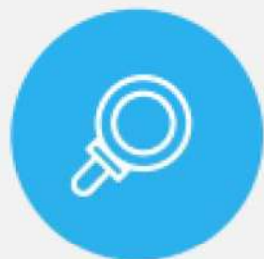
◆ 風險的特徵：以潛在事件發生的可能性與影響來描述，包括組織發展策略、產品與資安等層面。

◆ 應用的範圍：受內部與外部因素的影響，涵蓋組織的各階層，以及運作時的各面向。



認識風險管理

- ◆ 風險管理是對組織所有活動加以管理，控制所識別並關注的風險，在組織的目標下做好風險的管理。
- ◆ ISO 31000：2018 以風險管理的原則、框架與流程來鋪陳資訊安全風險管理的整體架構。



原則

風險管理必須引導所有相關的活動，有明確的原則，讓組織關注的風險受控制



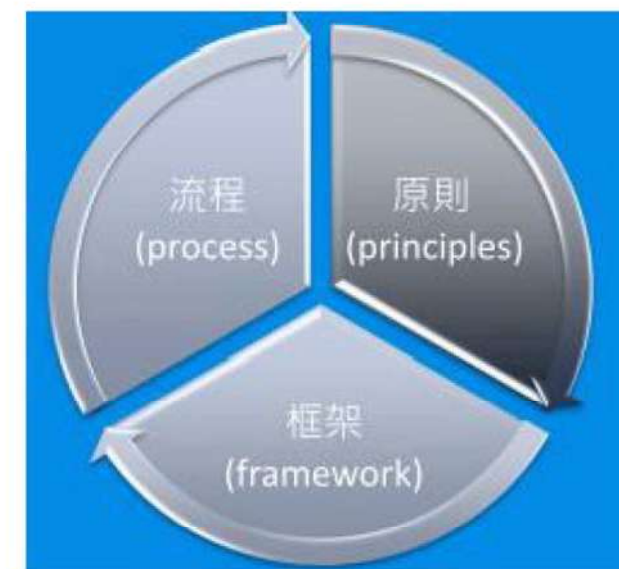
框架

組織的所有活動都要涵蓋在風險管理的範圍內。識別出風險並且進行分析，評估採用的風險處理的方法



流程

以系統化的方法來進行風險管理，使相關的活動能確實呼應組織的目標



認識風險管理

◆ 何謂風險(常用的精簡定義)：

威脅(Threat)利用資產(Asset)的脆弱性(Vulnerability)造成衝擊(Impact)的可能性(Likelihood)。

◆ 例如：

- 病毒(威脅)利用人(資產)的身體抵抗力弱(脆弱性)造成生病(衝擊)的可能性。
- 同樣的環境，抵抗力低的人，生病的風險高於抵抗高的人。
- 流感高峰期時，生病的風險就高於平時。

◆ 方法論要可比較且可重製

◆ 管控的強度，主要即是依據風險高低來決定->體質不好的人，平時需要花比較多的成本來注意身體健康。



資安風險管理的相關標準

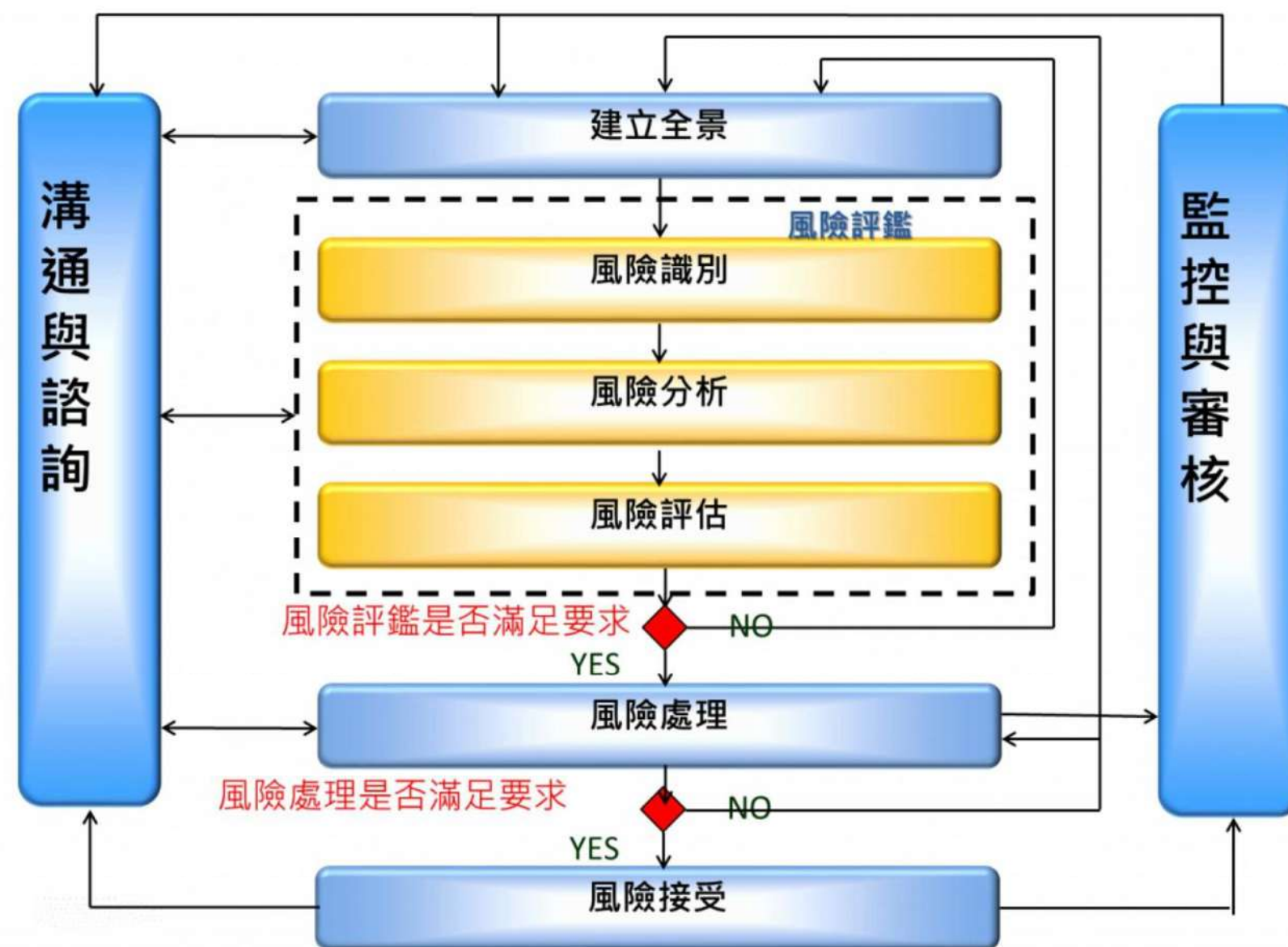
- ◆ 資訊安全風險管理的相關標準訂定了資安風險管理的架構，涵蓋風險管理的程序。

不同的標準的內容有一些差異，例如風險管理的標的會有不同的設定

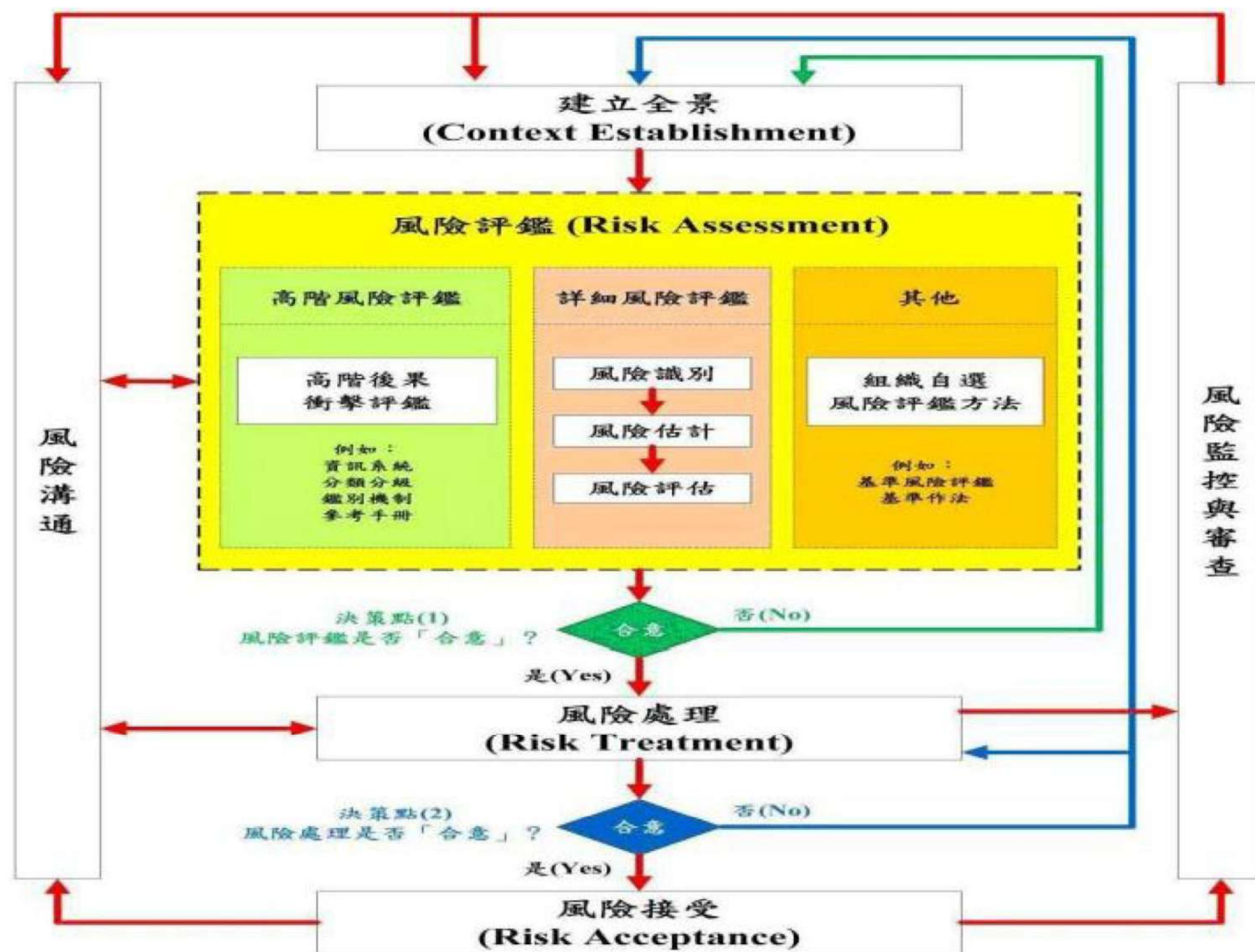
- **NISTSP800-39**：資訊系統風險管理的參考指引，是美國政府機關採用的風險管理方法，對象是資訊系統。
- **ISO27005**：資安風險管理指引，是 ISO/IEC 主導的風險管理方法，風險管理的對象由機構自行定義。
- **ISO31010:2009**：提供系統化的風險評鑑方法的選擇與應用，機構在決定是否進一步處理風險時可參考。

資訊安全風險管理的流程

- ◆ ISO 27005 資訊安全風險管理架構，包括 5 大階段，從「風險溝通與諮詢階段」、「建立全景階段」、「風險評鑑階段」、「風險處理階段」，到「風險監視與審查階段」



ISO27005 資訊安全風險管理架構



風險管理的流程

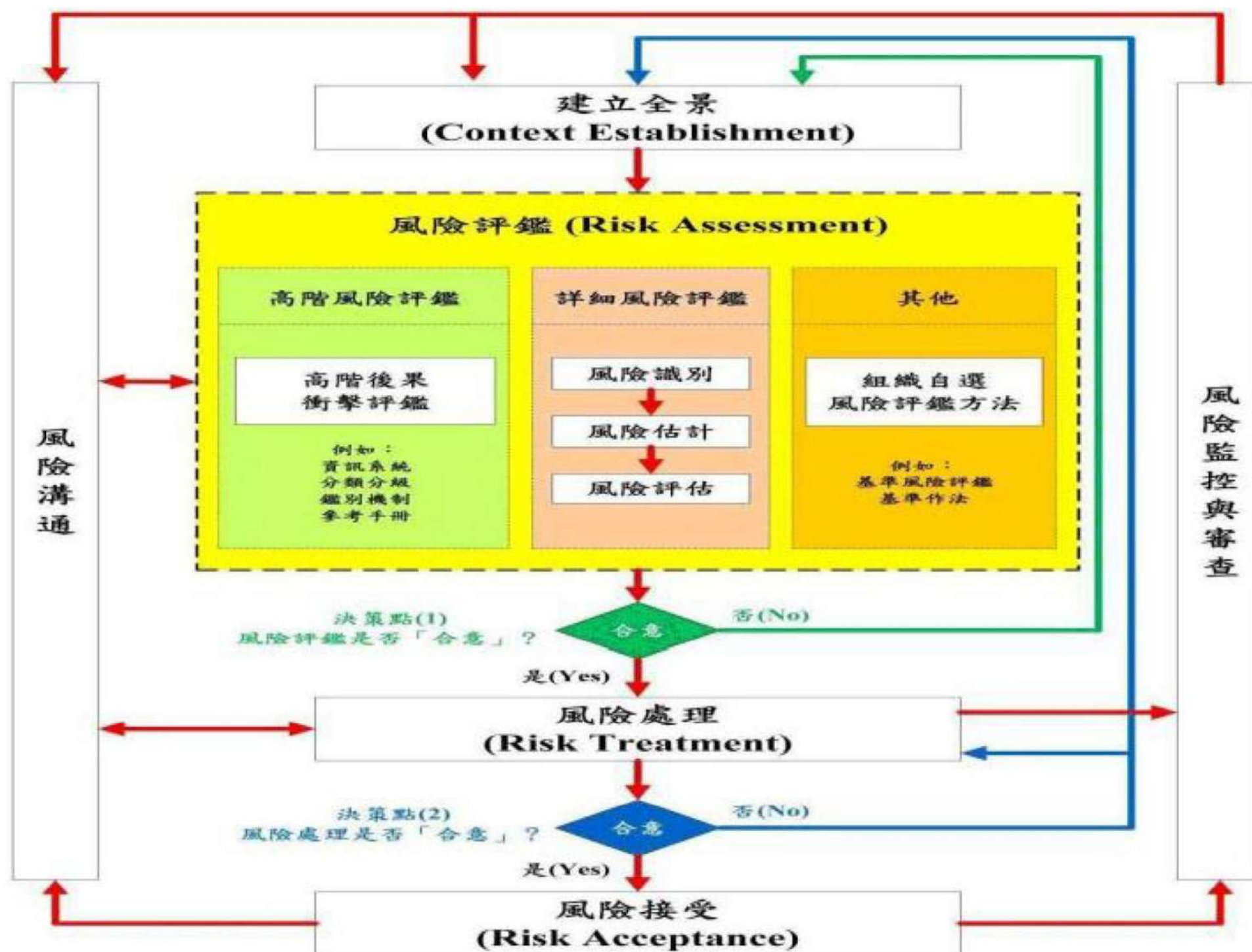
◆ 第一階段：風險溝通與諮詢階段

◆ 第二階段：建立全景階段

◆ 第三階段：風險評鑑階段

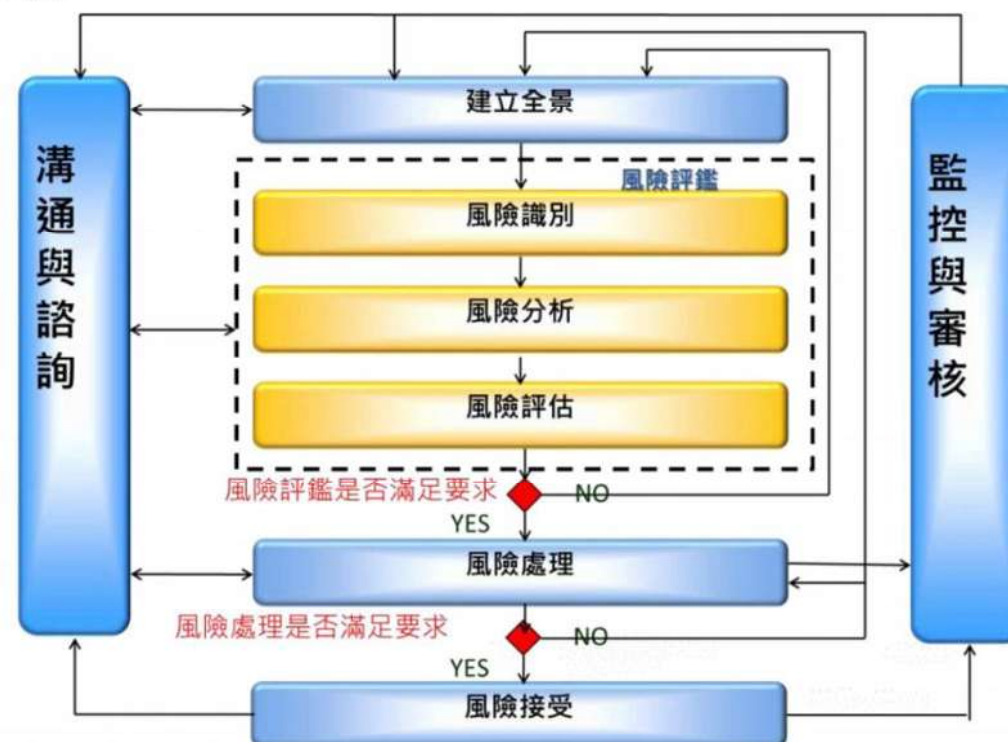
◆ 第四階段：風險處理階段

◆ 第五階段：風險監視與審查階段



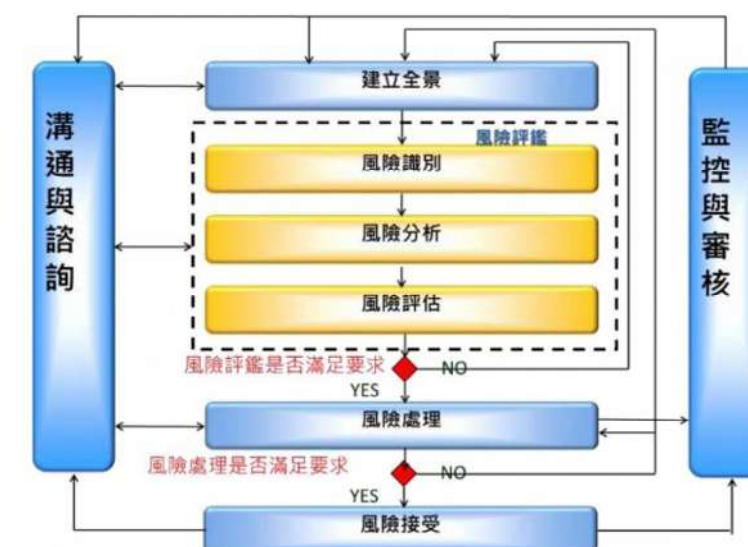
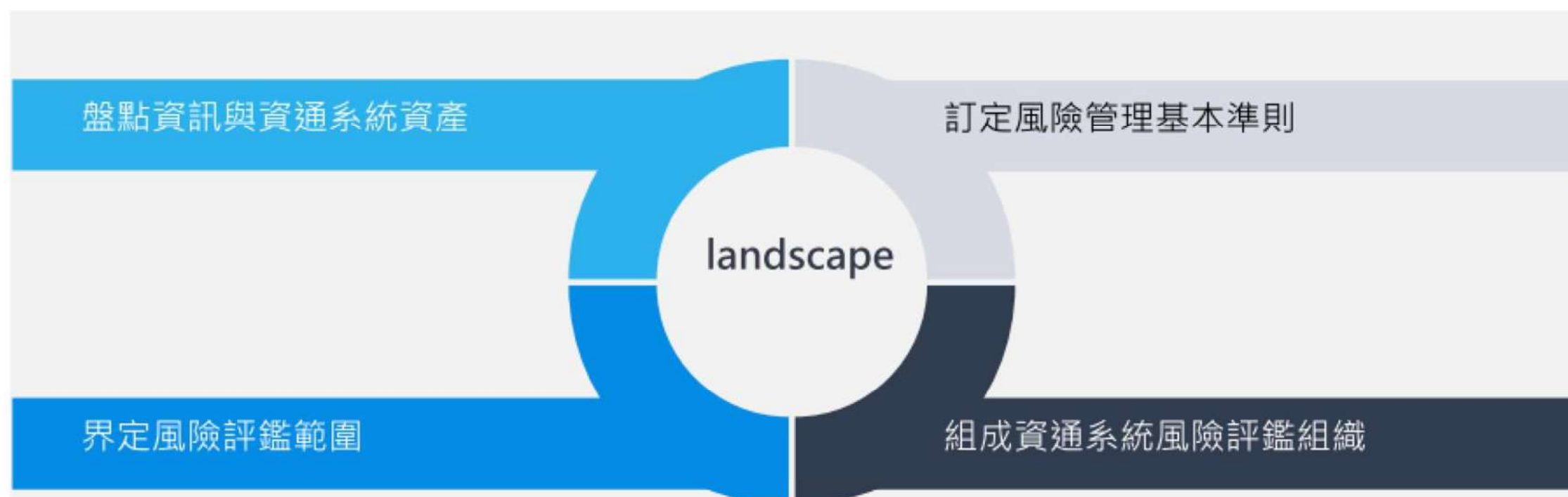
風險管理的流程 - 風險溝通與諮詢階段

- ◆ 在風險管理初期就要發展出溝通與諮詢的方法，讓後續的各階段能順利地跟利害關係人進行適當而有效的互動。
- ◆ 風險管理的初期就要發展出溝通與諮詢的方法，在後續的風險管理的各階段才能順利地與內部及外部的利害關係人溝通，對風險的存在、發生機會、影響等特性，透過溝通與諮詢來達成協議。
- ◆ 溝通與諮詢的團隊應包括各部門的成員與各領域的專家，協助建立風險管理全景，也就是全面的概觀。
- ◆ 確認利害關係人關心的議題，並對風險進行充分的識別，協同領域專家展開風險分析。
- ◆ 機構應發展出正常狀況與緊急狀況下的風險溝通與諮詢計畫，並成立負責協調風險溝通的作業小組。
- ◆ 在溝通上應強化對風險的認知，避免因缺乏互動造成資安漏洞，同時要提出風險評鑑結果與風險處理計畫。



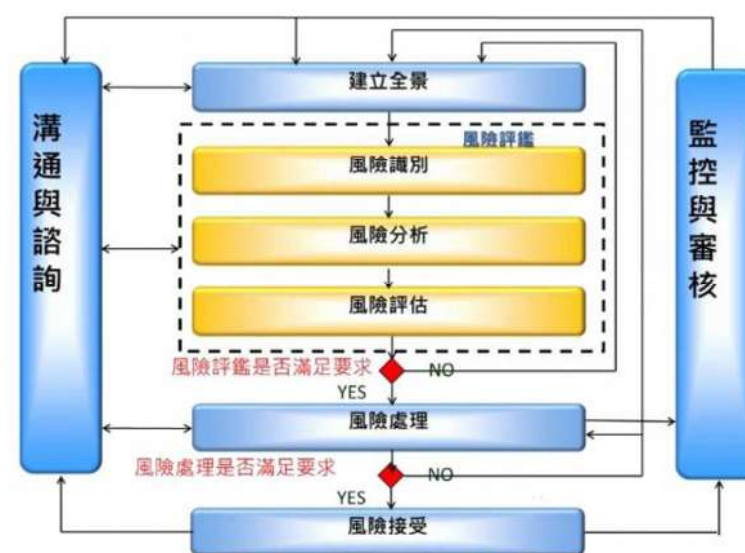
風險管理的流程 - 建立全景階段

- ◆ 從整體的角度先識別出組織內外的安全需求，確認風險評鑑的範圍。
- ◆ 訂定風險管理基本準則，先盤點出資訊資產，以此為基礎進行風險評鑑，在所界定的風險評鑑範圍內清查資通系統，找出相關的部門人員，成立資通系統風險評鑑組織。



風險管理的流程 - 風險評鑑階段

- ◆ 為了落實風險評鑑的執行，機構應發展適用於自身的風險管理基本準則，包括風險管理的作法、風險評估準則、衝擊準則，以及風險接受準則。
- **風險管理的作法**：每年針對資訊資產進行風險評估，自行或委外開發的資訊系統，應進行風險處理作業。
- **風險評估準則**：目的在於決定風險處理的優先順序，納入相關的考量因素，評估資安風險。
- **衝擊準則**：當威脅與脆弱性結合，資訊資產的機密性、完整性與可用性被破壞，應訂定對機構影響的嚴重性。
- **風險接受準則**：在資源有限的情況下，須決定影響層面大的風險優先處理，影響小的要暫時接受。



風險管理的流程 - 風險評鑑階段

◆ 依據全景階段訂定的範圍，以反覆的(iterative)方式對資通系統進行風險評鑑，包括高階風險評鑑與詳細風險評鑑。

◆ 風險評鑑的目的

1. 識別機構資訊資產的風險。先透過風險評鑑的程序識別資訊資產，並識別資訊資產的威脅、弱點、衝擊與對應的可能性，算出潛在風險值。
2. 依照風險的大小來決定風險處理的優先順序，風險評鑑沒有一定的作法，機構要客觀地評估面臨的風險，常見的方法包括高階風險評鑑與詳細風險評鑑。



風險管理的流程 - 風險評鑑階段 - 高階風險評鑑

- ◆ 不需要逐一地清查風險，可透過比較簡單的方式評估風險等級，例如分成「高」、「中」、「普」級，按照評出來的等級選擇安全控制措施來達到防護的效果。在實務上可參考政府「資訊系統分類分級與鑑別機制參考手冊」之高階風險評鑑作法
- ◆ 高階風險評鑑的優點是機構花費在風險評鑑上的資源比較少，需配合的基本防護措施有成本效益。
- ◆ 高階風險評鑑的缺點是比較無法兼顧機構的某些特性，對安全等級高的資訊資產仍建議採用詳細風險評鑑。
- ◆ 對資訊系統分類分級就是一種高階風險評鑑，機構可從機密性、完整性、可用性，與法律遵循性評估。從四大構面中得到的最高衝擊等級即可做為所評估資訊資產的安全等級。



風險管理的流程 - 風險評鑑階段詳細風險評鑑

- ◆ 透過系統化的方式，找出資訊資產須優先處理的風險，採用適當的安全控制措施。
- ◆ 優點是比較可能找出所有系統的適當保護措施；缺點是評鑑過程複雜，需要專業人員的協助。

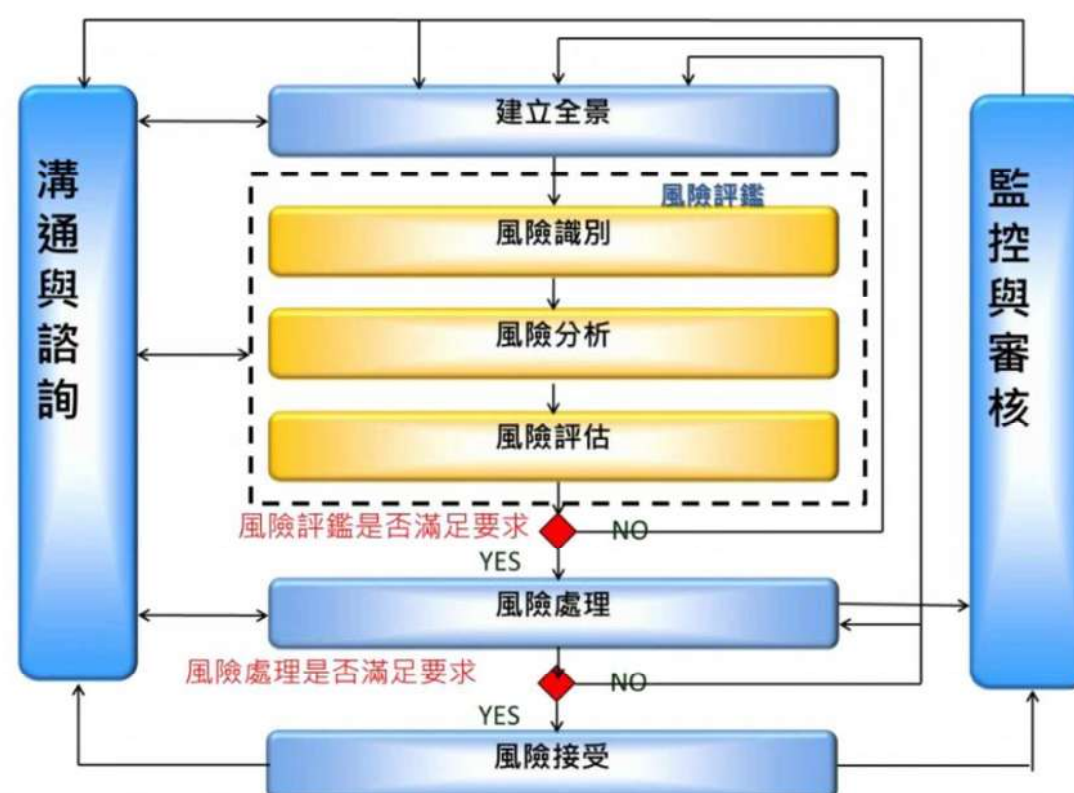
在實務上可參考「ISO/IEC27005」之詳細風險評鑑作法。

- ◆ **風險識別**：包含資產識別、威脅與脆弱性識別、現有控制措施識別、後果識別。
- ◆ **風險分析**：包含後果評鑑、事件可能性評鑑、決定風險等級。
- ◆ **風險評估**：決定風險可接受等級。



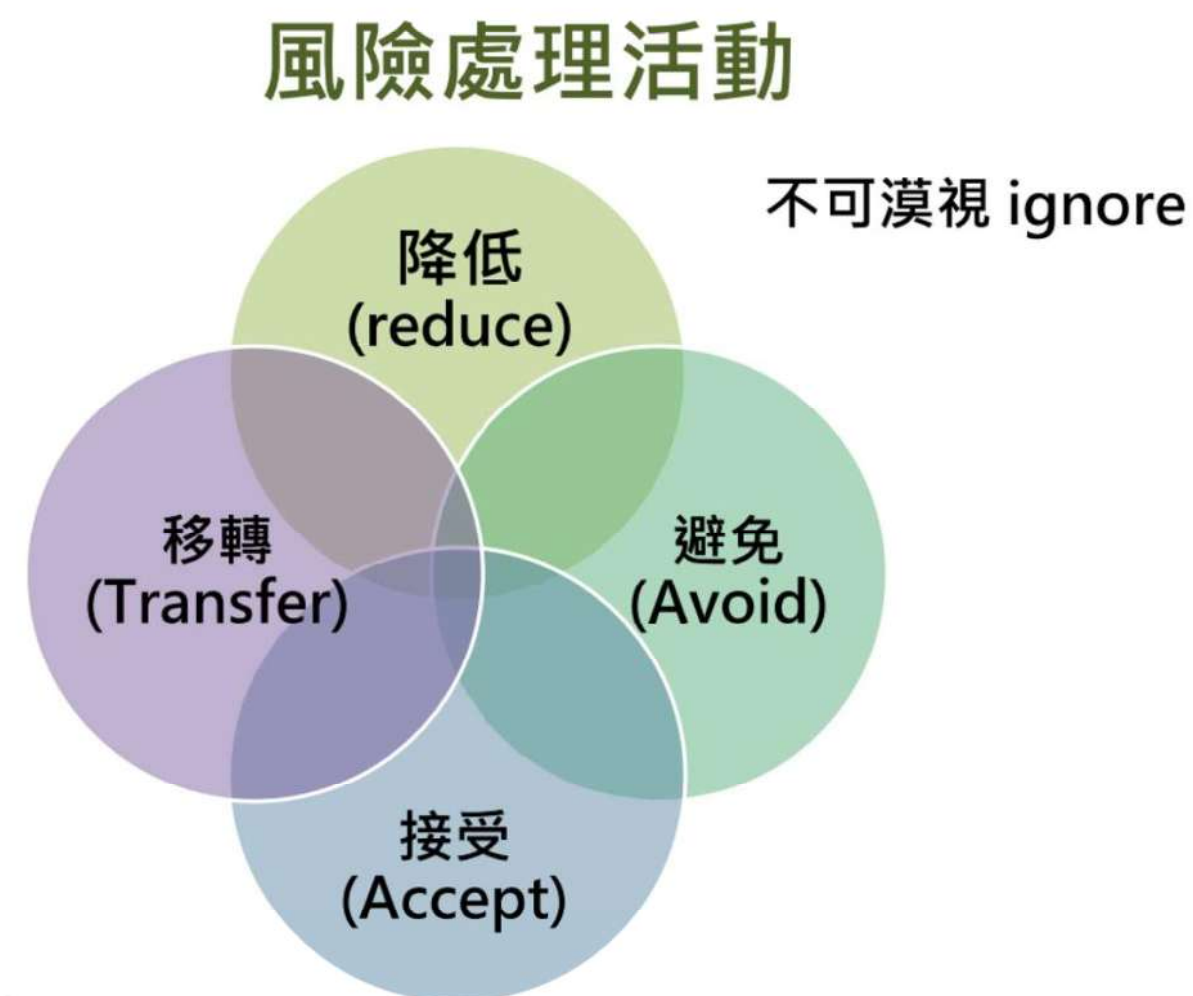
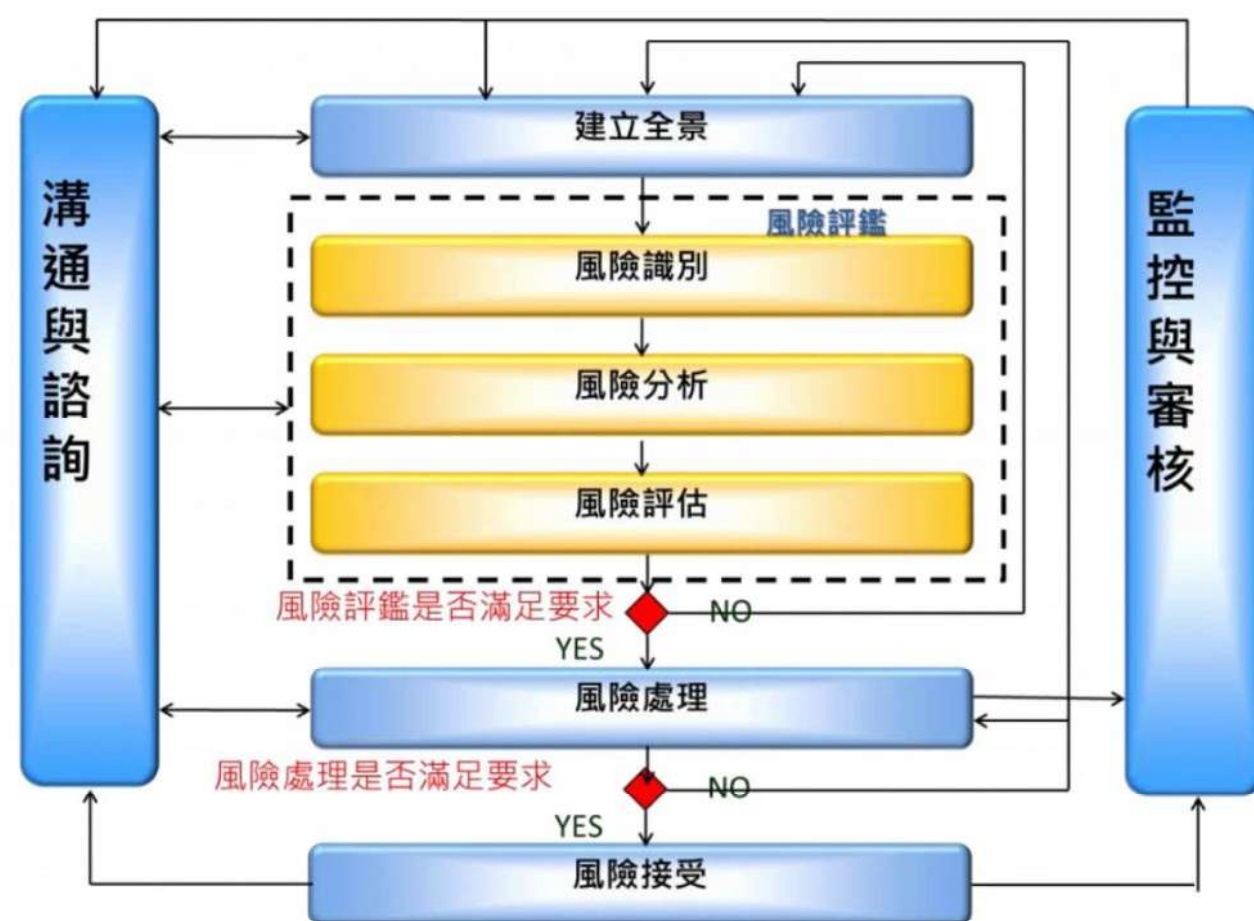
風險管理的流程 - 風險評鑑階段

- ◆ 從選用的風險評鑑方法得到結果以後，可以進行是否合乎要求的判斷與決策，必須達到合乎要求的結果才能進入風險處理的階段。
- **合乎要求的判斷**：須確認是否符合現況？不同評鑑者能否達到一致的結果？以及管理階層是否認同？
- **合乎要求**：確認風險評鑑結果合乎要求之後，即可直接進入風險處理的階段。
- **不合乎要求**：假如風險評鑑結果不合乎要求，則要回到全景階段，開始一個新的風險管理循環。

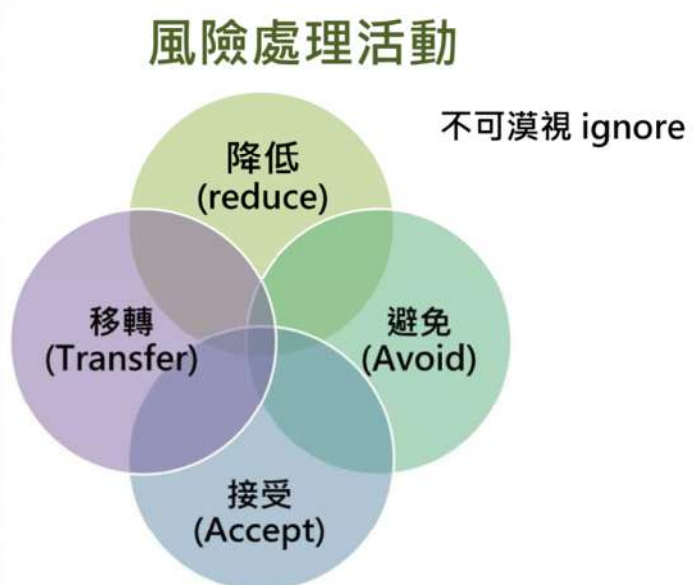


風險管理的流程 - 風險處理階段

- ◆ 有了風險評鑑的結果以後，必須進一步地選擇適當的風險處理方式，合理降低風險的負面影響。
- ◆ 風險處理計畫：依據風險評鑑的結果，找出需要降低風險的項目，高風險的項目要優先處理，規劃適當的控制措施，並進行殘餘風險的評估。



風險處理活動



01 風險修改

風險降低

透過實施、移除或改變安全控制措施，修訂或降低風險等級，殘餘的風險可重新評定成可接受風險

02 風險保留

風險接受

依據風險評估結果，不需要進一步的行動，因此保留風險，這是因為風險等級符合**風險接受準則**

03 風險避免

風險避免

撤出已經規劃的活動，完全避免風險，例如撤下已有風險的授權舊版軟體，避免機構有人繼續下載安裝

04 風險分擔

風險分擔

將部分風險分擔至能有效管理風險的另外一方，例如資訊硬體毀壞的風險可以透過保險來分擔

風險管理的流程 - 風險監視與審查階段

◆ 資訊安全的威脅隨時在改變，風險管理也要隨時調整因應。

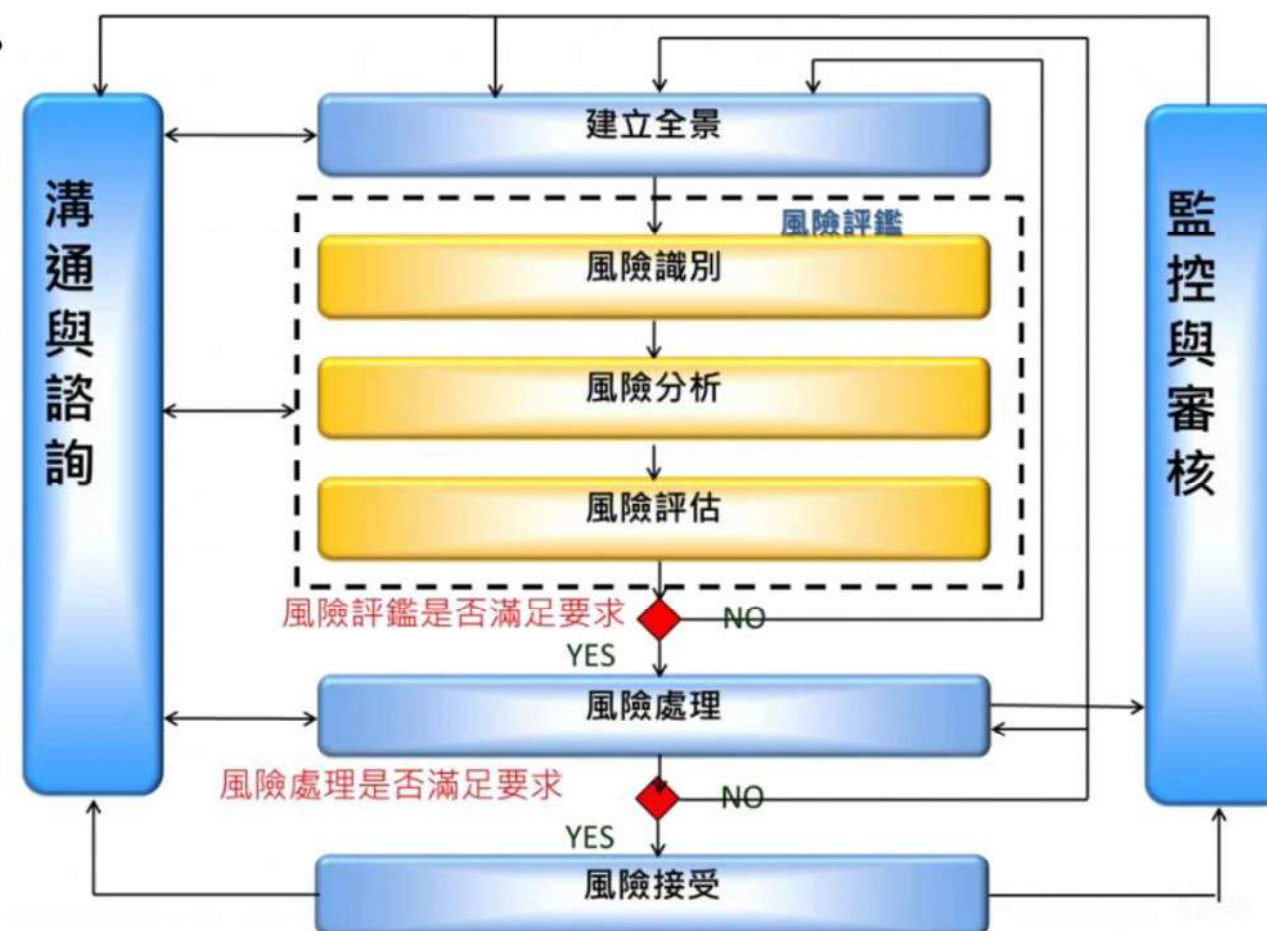
◆ 風險因素的監視與審查：

➤ 風險評鑑報告應該定期審核，環境或是資通系統有重大變化時，應進行對應的檢視與必要的更新，可透過變更管理來運作。

常見的異動原因包括法規合約改變、資安政策改變、資安事件應變等。

➤ 應透過內部稽核來確保安全控制措施的有效性，包括準備、開始會議、稽核審查、結束會議與稽核報告等階段。

➤ 稽核資料應妥善保管，透過資安稽核作業持續改善，亦可透過第三方進行外部稽核。

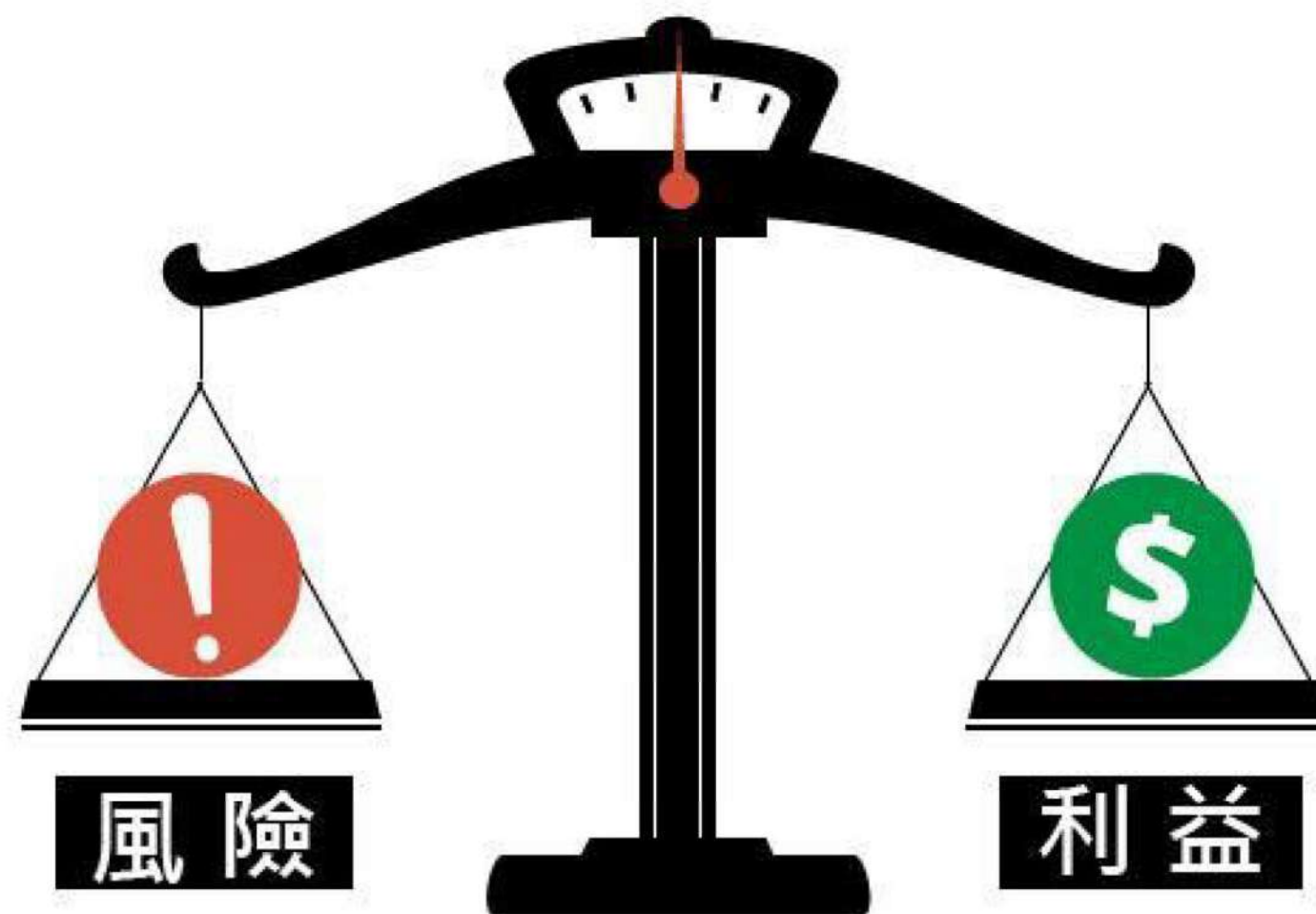


矯正預防

- ◆ 依據內部稽核與外部稽核的結果，進行持續改善。對於風險評鑑不符合或是需調整改進的項目，採取矯正控制措施與預防控制措施，落實管理執行的成效。
- **持續改善**：依據資安法規、資安政策、內外稽結果、事件分析與矯正預防措施，持續改善。
- **矯正控制措施**：防止資安事件再發生所提出的措施，消除與資安管理要求不符合的原因，應以文件記錄。
- **預防控制措施**：依管理程序定期檢視風險評鑑控制措施的合適性，消除與資安管理要求潛在不符合的原因。

風險接受準則

- ◆ 風險接受準則是用來判斷風險是否可以接受或必須要進行處理的原則，例如：可接受風險的評估原則。
- ◆ 通常依據組織政策、目標及業務關係來定義可接受或不可接受的狀況與條件。
- ◆ 可參考接受的原因：
 - 風險處理成本高過損失。
 - 有能力處理相關安全事故。
 - 尚無有效處理風險的技術。



資訊安全風險評鑑的實務

- ◆ 透過實務來了解資訊安全風險評鑑的細節與實際作為，能有效參與與執行資訊安全的風險管理。
- ◆ 高階風險評鑑的實務：依據資訊系統的業務，從機密性、完整性、可用性，與法律遵循性一共四個影響構面進行衝擊分析，以得到的最高衝擊等級為資訊系統的安全等級。
 - **設定影響構面的等級**：由業務承辦人評估當資安事件發生時，對四大構面的衝擊程度，評出普、中、高的等級。
 - **識別業務屬性並檢視安全等級**：識別資訊系統的業務特性，由承辦單位主管檢視並確認安全等級是否合理。
 - **核定資訊系統安全等級**：綜合整理出各資訊系統的安全等級評估表，經主管確認後再由資訊安全長核定。

重要名詞定義

- ◆ 資產弱點：資訊資產本身存在之特性，可被威脅利用而使得資訊資產遭受破壞。
- ◆ 風險識別與分析：可利用弱點，進而對資訊資產造成破壞的外在因素。各類弱點會因為不同威脅的發生而產生風險，因此需考量威脅發生之重大性。
- ◆ 可接受風險：由資訊安全組織依所面臨之風險及所願意投入之資源，而決定風險可接受水準，以作為控管機制設計執行者。
- ◆ 殘餘風險管理(接受風險、移轉風險、降低風險、規避風險)：當控管規範或機制增加或強化後，應重新評估風險權值，並重複執行辨認及降低風險步驟，直到降低到風險可接受水準為止。

Q&A